ĐẠI HỌC QUỐC GIA HÀ NỘI
TRƯỜNG ĐẠI HỌC CÔNG NGHỆ

BÁO CÁO BÀI TẬP LỚN

NGHIÊN CỨU CƠ CHẾ XÁC THỰC VÀ QUẢN LÝ CHỨNG THƯ SỐ X.509 TRONG PKI

Kiến trúc, Chuỗi tin cậy và Đánh giá thực nghiệm

Học phần:	Mật mã và An toàn thông tin
Mã lớp học phần:	2627I_INT3230_2
Thành viên thực hiện:	Đoàn Văn Tuyền (MSSV: 23020151)
	Vũ Minh Quân (MSSV: 23020142)
	Nguyễn Chi Tú (MSSV: 23020148)
Học kỳ / Năm học:	Học kỳ I, Năm học 2026–2027

Hà Nội, Tháng 10/2026

Tóm tắt

Cần viết sau khi có kết quả thực nghiệm: nêu vấn đề, phương pháp, số ca kiểm thử, kết quả quan sát và đóng góp thực tế của nhóm trong khoảng 150–250 từ.

Abstract

To be written after the experiment: summarize the research question, method, observed results, and limitations.

Mục lục

Tóm tắt i

Abstract ii

1 Giới thiệu và xác định vấn đề nghiên cứu 1

1.1 Bối cảnh và bài toán . . . 1

1.1.1 Bối cảnh mật mã khóa công khai . . . 1

1.1.2 Quá trình truyền thông điệp mã hóa trong điều kiện lý tưởng . . . 1

1.1.3 Cuộc tấn công thay thế khóa của Eve . . . 2

1.1.4 Phân tích bản chất bài toán và vai trò của PKI . . . 3

1.2 Mục tiêu và câu hỏi nghiên cứu . . . 5

1.3 Phạm vi và phương pháp nghiên cứu . . . 6

1.4 Cấu trúc của báo cáo . . . 6

2 Cơ sở mật mã khóa công khai và PKI 8

2.1 Yêu cầu bảo mật và quản lý khóa . . . 8

2.1.1 Yêu cầu bảo mật trong truyền thông và vai trò của PKI . . . 8

2.1.2 Nguyên lý quản lý khóa và vòng đời khóa mật mã . . . 8

2.2 Khóa công khai, hàm băm và chữ ký số . . . 9

2.3 Vai trò thuật toán trong TLS . . . 10

3 Kiến trúc PKI và vòng đời chứng thư 13

3.1 Thành phần và mô hình tin cậy . . . 13

3.1.1 Các thành phần cốt lõi trong PKI . . . 13

3.1.2 Mô hình tin cậy phân cấp (Hierarchical Trust Model) . . . 14

3.2 Vòng đời chứng thư . . . 15

3.2.1 Các giai đoạn và nhánh rẽ trong vòng đời chứng thư . . . 16

3.2.2 Ánh xạ giai đoạn vòng đời chứng thư với công cụ OpenSSL và kịch bản thực nghiệm . . . 18

3.2.3 Phân biệt Yêu cầu ký chứng thư (CSR) và Chứng thư số đã phát hành . . . 18

3.3 Chính sách vận hành . . . 18

3.3.1 Phân định vai trò giữa CP và CPS . . . 19
3.3.2 Quản lý và bảo vệ khóa bí mật của CA (Mục 6 của dàn bài RFC 3647) . . . 19
3.3.3 Phân quyền và các biện pháp kiểm soát thủ tục (Mục 5.2 của dàn bài RFC 3647) . . . 20
3.3.4 Ghi nhận nhật ký và đánh giá tuân thủ (Mục 5.4 và Mục 8 của dàn bài RFC 3647) . . . 21
3.3.5 Đối chiếu chính sách CA thực tế và môi trường thực nghiệm của nhóm . . . 21

4 X.509, chuỗi tin cậy và cơ chế xác thực 24
4.1 Cấu trúc chứng thư X.509 v3 . . . 24
4.1.1 Các trường dữ liệu chuẩn (Standard Fields) . . . 24
4.1.2 Các phần mở rộng X.509 v3 quan trọng (Standard Extensions) . . . 25
4.1.3 Trích xuất thực tế cấu trúc chứng thư trong môi trường Lab . . . 26
4.2 Xây dựng và xác minh đường dẫn . . . 27
4.2.1 Chuỗi chứng thư trong lab . . . 28
4.2.2 Quy trình xây dựng và xác minh . . . 29
4.2.3 Quan sát từ lab . . . 31
4.3 Thu hồi và trạng thái chứng thư . . . 31
4.3.1 Danh sách thu hồi chứng thư (CRL) . . . 31
4.3.2 Giao thức trạng thái chứng thư trực tuyến (OCSP) . . . 32
4.3.3 So sánh CRL và OCSP . . . 32
4.3.4 Trạng thái `good` không đồng nghĩa với chứng thư hợp lệ . . . 33
4.4 Liên hệ TLS . . . 33
4.4.1 Chứng thư và `CertificateVerify` trong bắt tay TLS 1.3 . . . 33
4.4.2 Phân định các kiểm tra . . . 34

5 Phân tích bảo mật, mô hình tấn công và so sánh 36
5.1 Tài sản, đối thủ và rủi ro . . . 36
5.1.1 Tài sản cần bảo vệ . . . 36
5.1.2 Mô hình đối thủ và giả định . . . 37
5.1.3 Các mối đe dọa và rủi ro . . . 37
5.1.4 Phân tích trường hợp DigiNotar . . . 37
5.2 So sánh các cơ chế tin cậy và thu hồi . . . 39
5.2.1 Ba mô hình tin cậy . . . 39
5.2.2 Thu hồi và rút ngắn thời hạn . . . 40
5.3 Giới hạn của chữ ký hợp lệ . . . 41

6 Thiết kế và đánh giá thực nghiệm 44
6.1 Giả thuyết và môi trường . . . 44

6.1.1 Các giả thuyết nghiên cứu 44
6.1.2 Môi trường thực nghiệm 44
6.2 Mô hình và quy trình 45
6.2.1 Mô hình phân cấp chứng thư (PKI Hierarchy) 45
6.2.2 Cấu hình X.509 Extensions và Chính sách xác minh 45
6.2.3 Quy trình thực nghiệm 47
6.3 Test cases và kết quả 47
6.3.1 Bảng kết quả thực nghiệm quan sát 47
6.3.2 Phân tích chi tiết các trường hợp quan sát 49
6.4 Thảo luận và hạn chế 49
6.4.1 Đánh giá và trả lời các giả thuyết nghiên cứu 49
6.4.2 Hạn chế của bài lab 50

7 Ứng dụng và hướng phát triển PKI **51**
7.1 Ứng dụng và Certificate Transparency 51
7.2 Tự động hóa và hậu lượng tử 51

Kết luận và hướng phát triển **52**

Danh sách bảng

2.1 Phân định phạm vi hỗ trợ của PKI đối với mục tiêu an ninh thông tin . . 9
2.2 So sánh bản chất và vai trò của các thành phần mật mã trong PKI 11
2.3 Phân định vai trò các thuật toán mật mã trong giao thức TLS 1.3 12
3.1 Tổng hợp vai trò và đặc điểm vận hành của các thành phần trong PKI. . . 14
3.2 Ánh xạ các giai đoạn vòng đời chứng thư X.509 với lệnh OpenSSL và ca kiểm thử. 19
3.3 Phân biệt bản chất kỹ thuật giữa CSR và chứng thư số X.509 20
3.4 So sánh đối chiếu giữa khung RFC 3647, CA thực tế và bài lab 23
4.1 Các điều kiện xác minh đường dẫn và ca kiểm thử tương ứng 30
4.2 So sánh CRL và OCSP 32
4.3 Phân định các kiểm tra trong kết nối TLS 1.3 35
5.1 Tài sản cần bảo vệ trong mô hình PKI phân cấp 36
5.2 Các mối đe dọa và cơ chế kiểm soát trong PKI 38
5.3 So sánh ba mô hình tin cậy theo giả định tin cậy 40
5.4 So sánh CRL, OCSP và chứng thư thời hạn ngắn 41
6.1 Kết quả quan sát thực nghiệm bộ 10 ca kiểm thử PKI (TC01–TC10). . . . 48

Danh sách hình vẽ

1.1 Mô hình trao đổi thông tin thông thường và kịch bản tấn công thay thế khóa của Eve. 4
3.1 Kiến trúc các thành phần và luồng dữ liệu cấp phát, xác thực trong mô hình PKI phân cấp. 15
3.2 Các giai đoạn và nhánh rẽ trong vòng đời chứng thư X.509 16
4.1 Kết quả thực thi lệnh trích xuất cấu trúc chứng thư X.509 v3 của máy chủ TLS (`server-a.crt`) trong môi trường thực nghiệm. 27
4.2 Chuỗi chứng thư Root CA → Intermediate CA → server trong lab: quan hệ ký phát và quan hệ thẩm định giữa các mắt xích. 29
4.3 Kết quả `openssl verify` với chuỗi đầy đủ (OK) và khi thiếu chứng thư Intermediate CA (lỗi 20, TC06). 31
5.1 Minh chứng thực nghiệm: Cùng một chứng thư có chữ ký hợp lệ nhưng bị từ chối ở các tầng kiểm tra ngữ cảnh khác nhau (TC01, TC04, TC03, TC07, TC08). 42
6.1 Thông số môi trường hệ điều hành, phần cứng và phiên bản OpenSSL thực tế của bài lab. 45
6.2 Mô hình phân cấp chứng thư X.509 hai tầng triển khai trong phòng lab thực nghiệm. 46
6.3 Tổng hợp kết quả thực thi tự động bộ 10 ca kiểm thử PKI qua script `run_tests.sh`. 47

Chương 1

Giới thiệu và xác định vấn đề nghiên cứu

1.1 Bối cảnh và bài toán

1.1.1 Bối cảnh mật mã khóa công khai

Trong các hệ thống thông tin, việc truyền thông qua mạng công cộng luôn đối mặt với nguy cơ bị nghe lén và can thiệp. Mật mã khóa công khai ra đời từ công trình của Diffie và Hellman (1976) [1], tiếp nối bởi hệ mật RSA của Rivest, Shamir và Adleman (1978) [2], nhằm giải quyết hạn chế phân phối khóa bí mật chung của mật mã đối xứng. Trong mật mã khóa công khai, mỗi thực thể sở hữu một cặp khóa có quan hệ toán học chặt chẽ nhưng không thể suy dẫn khóa này từ khóa kia với năng lực tính toán thực tế: **Khóa công khai (Public Key -** PU/PK**)** được công bố rộng rãi mà không cần giữ bí mật; còn **Khóa bí mật (Private Key -** PR/SK**)** được chủ sở hữu lưu giữ bí mật và không tiết lộ cho bên thứ ba.

Quy ước ký hiệu cặp khóa: Hai hệ ký hiệu (PU, PR) và (PK, SK) tương đương nhau về bản chất. Nhằm trực quan với kịch bản truyền thông kinh điển giữa Alice, Bob và Eve, Chương 1 sử dụng hệ ký hiệu (PU_B, PR_B) và (PU_E, PR_E). Từ Chương 2 trở đi, tài liệu sử dụng thống nhất ký hiệu chuẩn mực (PK, SK) (ví dụ: SK_{CA}, PK_{server}).

Xét kịch bản kinh điển: Alice gửi thông điệp, Bob nhận thông điệp, và Eve là đối thủ có khả năng giám sát, đánh chặn hoặc sửa đổi gói tin. Để gửi thông điệp bí mật đến Bob, Alice dùng khóa công khai của Bob để mã hóa. Vấn đề cốt lõi là: *Làm thế nào Alice xác minh khóa công khai nhận được thực sự thuộc về Bob, chứ không phải do đối thủ Eve giả mạo?*

1.1.2 Quá trình truyền thông điệp mã hóa trong điều kiện lý tưởng

Trong điều kiện lý tưởng, khi kênh truyền không bị can thiệp và khóa công khai chuyển giao toàn vẹn:

1. Bob khởi tạo cặp khóa gồm khóa công khai PU_B và khóa bí mật PR_B.
2. Bob cung cấp khóa công khai PU_B cho Alice qua kênh mạng.

3. Alice dùng khóa công khai PU_B của Bob cùng hàm mã hóa $E(\cdot)$ để mã hóa thông điệp M, tạo thành bản mã C:

$$C = E(PU_B, M) \tag{1.1}$$

4. Bob nhận bản mã C và dùng khóa bí mật tương ứng PR_B cùng hàm giải mã $D(\cdot)$ để khôi phục thông điệp M:

$$M = D(PR_B, C) \tag{1.2}$$

Mô hình lý thuyết trên minh họa nguyên lý cơ bản. Trong thực tế, các giao thức an toàn như TLS 1.3 [3] áp dụng mô hình mật mã lai: dùng khóa công khai để xác thực và thỏa thuận khóa phiên (ECDHE), rồi dùng thuật toán đối xứng (như AES-GCM) để mã hóa dữ liệu (Mục 2.3). Cơ chế này chỉ an toàn khi Alice nhận đúng khóa PU_B của Bob và thuật toán là an toàn. Nếu Alice bị lừa dùng một chiếc khóa khác, tính bí mật sẽ bị phá vỡ hoàn toàn.

1.1.3 Cuộc tấn công thay thế khóa của Eve

Khi phân phối khóa công khai trên kênh mở mà thiếu cơ chế xác thực nguồn gốc, đối thủ Eve có thể thực hiện tấn công thay thế khóa theo phương thức người đứng giữa (*Man-in-the-Middle - MITM*). Giả sử Eve sở hữu cặp khóa (PU_E, PR_E). Cuộc tấn công diễn ra qua 6 bước:

1. Bob gửi khóa công khai PU_B cho Alice qua mạng.

2. Eve chặn thông điệp chứa PU_B trên đường truyền và thay bằng khóa của mình là PU_E.

3. Alice nhận được PU_E nhưng nhầm là của Bob; do đó Alice dùng PU_E để mã hóa thông điệp M:

$$C_1 = E(PU_E, M) \tag{1.3}$$

4. Alice gửi bản mã C_1. Eve chặn C_1 và dùng khóa bí mật PR_E để giải mã:

$$M = D(PR_E, C_1) \tag{1.4}$$

   Tại thời điểm này, Eve đọc được trọn vẹn nội dung thông điệp gốc M.

5. Để duy trì ngụy trang, Eve dùng khóa công khai thật của Bob (PU_B) để mã hóa lại M:

$$C_2 = E(PU_B, M) \tag{1.5}$$

   sau đó chuyển tiếp bản mã C_2 tới Bob dưới danh nghĩa Alice.

6. Bob nhận được C_2, dùng khóa bí mật PR_B để giải mã:

$$M = D(PR_B, C_2) \tag{1.6}$$

   Bob khôi phục đúng thông điệp M ban đầu và không nhận ra cuộc tấn công nếu thiếu cơ chế xác thực thích hợp.

Cuộc tấn công MITM thành công vì Alice không có khả năng xác minh tính xác thực của khóa công khai nhận được. Mô hình trao đổi thông thường và cuộc tấn công thay thế khóa được minh họa tại Hình 1.1.

Cần phân biệt rõ hai mức độ đe dọa khác nhau: (i) Eve tự ý tráo khóa trên đường truyền (MITM thông thường), và (ii) Eve sở hữu một chứng thư giả mạo do một CA đáng tin cậy cấp phát. Trong trường hợp thứ nhất, chữ ký số của CA trên chứng thư giúp người nhận kiểm tra khóa công khai có thực sự được bảo chứng bởi CA đó hay không; tuy nhiên, người nhận vẫn phải thực hiện thẩm định toàn diện chuỗi tin cậy, thời hạn hiệu lực, danh tính máy chủ và trạng thái thu hồi. Trong trường hợp thứ hai, nếu CA bị xâm nhập và cấp chứng thư giả mạo, việc kiểm tra chữ ký đơn thuần sẽ hoàn toàn bất lực trong việc phát hiện gian lận.

1.1.4 Phân tích bản chất bài toán và vai trò của PKI

Kịch bản tấn công của Eve cho thấy tính bí mật của dữ liệu chỉ có ý nghĩa khi khóa công khai được xác thực nguồn gốc. Dù các thuật toán mật mã hoạt động đúng đắn về mặt toán học (C_1 giải mã đúng bằng PR_E, C_2 giải mã đúng bằng PR_B), an toàn hệ thống vẫn bị phá vỡ vì khóa đưa vào bị đánh tráo. Hậu quả là kẻ tấn công có thể nghe lén, giả mạo danh tính (impersonation) hoặc sửa đổi dữ liệu (tampering) mà các bên không phát hiện được.

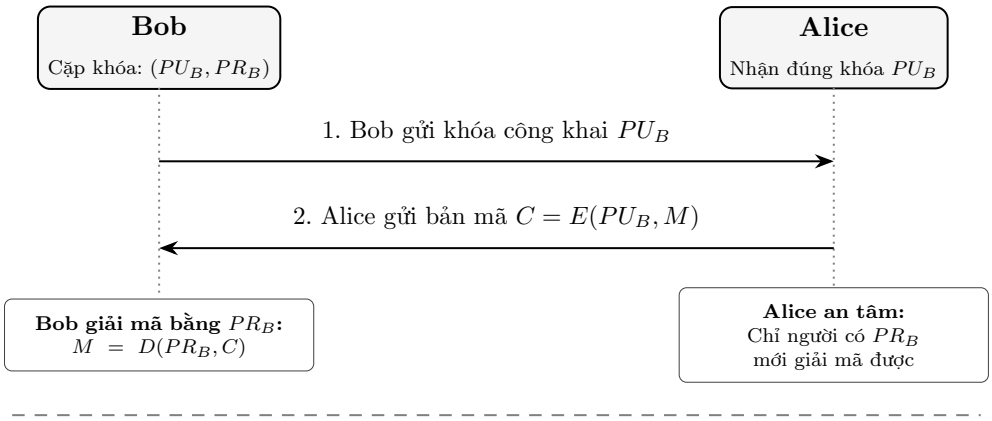
Do đó, thách thức cốt lõi là: **Phải có một cơ chế đáng tin cậy để liên kết (bind) một khóa công khai cụ thể với danh tính thực tế của chủ sở hữu hợp pháp**.

Để giải quyết thách thức này, **Hạ tầng khóa công khai (Public Key Infrastructure - PKI)** được chuẩn hóa và triển khai. PKI là hệ thống hạ tầng toàn diện bao gồm chính sách, tiêu chuẩn, phần cứng và phần mềm, thiết lập mối liên kết tin cậy qua ba cấu phần cốt lõi: *Tổ chức chứng thực số (CA)* đóng vai trò bên thứ ba đáng tin cậy thẩm tra danh tính; *Chứng thư số (chuẩn ITU-T X.509)* đóng gói khóa công khai cùng thông tin định danh của chủ thể (Subject); và *Chữ ký số* do CA tạo bằng khóa bí mật của mình để đảm bảo tính toàn vẹn và chống chối bỏ cho liên kết đó.

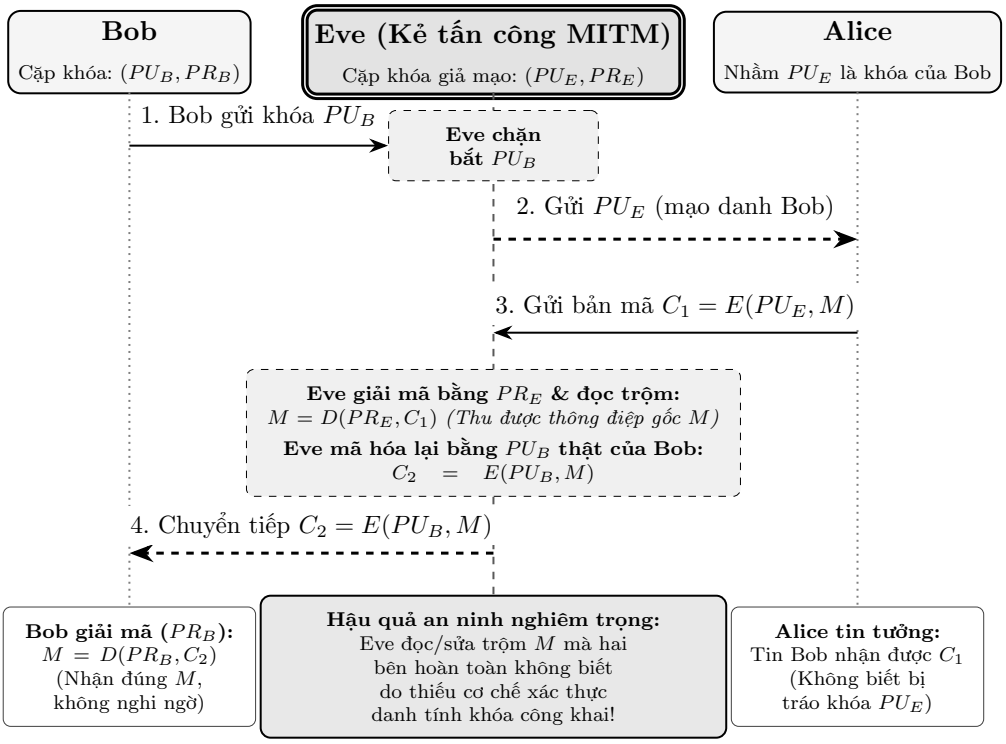
Trong môi trường PKI, Alice nhận được chứng thư số của Bob do CA ban hành. Để chấp nhận chứng thư, Alice thực hiện quy trình thẩm định đường dẫn theo 6 bước:

1. **Xây dựng chuỗi tin cậy (Path Building):** Truy vết chuỗi từ chứng thư Bob ngược về Trust Anchor trong Trust Store cục bộ.
2. **Xác thực chữ ký số (Signature Verification):** Dùng khóa công khai của CA tương ứng kiểm tra chữ ký số trên từng mắt xích.
3. **Thẩm định ràng buộc cơ bản (Constraints Verification):** Kiểm tra extension `basicConstraints` (cờ `cA`, `pathLen`) ngăn chặn mạo danh CA.
4. **Đối chiếu mục đích sử dụng khóa (Key Usage / EKU):** Đối chiếu `KeyUsage` và `ExtendedKeyUsage` bảo đảm đúng mục đích cấp.
5. **Khớp định danh chủ thể (Identity Matching):** Kiểm tra trường SAN xem tên miền truy cập có trùng khớp với đối tác hay không.
6. **Kiểm tra thời hạn hiệu lực và trạng thái thu hồi:** Đối chiếu thời gian với khoảng [`notBefore`, `notAfter`] và kiểm tra thu hồi qua CRL hoặc OCSP.

(a) Trao đổi bình thường qua kênh truyền không bảo vệ (Kịch bản lý tưởng)



(b) Kịch bản tấn công Man-In-The-Middle (Eve can thiệp và tráo đổi khóa)



Hình 1.1: Mô hình trao đổi thông tin thông thường và kịch bản tấn công thay thế khóa của Eve.

Giới hạn của PKI và sự cố thực tế kinh điển (DigiNotar 2011): Tuy vậy, PKI về bản chất là một hạ tầng quản trị niềm tin (*trust management*); an ninh hệ thống phụ thuộc chặt chẽ vào chính sách vận hành và tính toàn vẹn của các CA gốc. Minh chứng điển hình là **sự cố DigiNotar (2011)** [4]: khi CA công cộng của Hà Lan này bị xâm nhập, tin tặc đã phát hành tối thiểu 531 chứng thư giả mạo có chữ ký mật mã hoàn toàn hợp lệ cho `*.google.com` cùng nhiều tổ chức khác. Kẻ tấn công dùng các chứng thư này để triển khai MITM đối với khoảng 298.140 địa chỉ IP (ước tính thô), trong đó xấp xỉ 95% ở Iran. Sự cố chỉ được phát hiện khi trình duyệt Google Chrome chặn chứng thư giả mạo nhờ cơ chế ghim chứng thư (*Certificate Pinning*) vào ngày 28/08/2011, dẫn đến việc DigiNotar bị thu hồi và xóa vĩnh viễn khỏi Trust Store toàn cầu. Sự cố khẳng định chữ

ký toán học đúng chỉ là điều kiện cần nhưng chưa đủ nếu quy trình vận hành và kiểm soát hạ tầng CA bị buông lỏng (xem chi tiết tại Mục 3.3.4 và Chương 5).

Từ đó, bài toán nghiên cứu trọng tâm là: **Làm thế nào để phân phối và xác thực khóa công khai một cách đáng tin cậy, hạn chế tối đa nguy cơ giả mạo và tấn công thay thế khóa, đồng thời đánh giá được các điều kiện chấp nhận và giới hạn an ninh của hệ thống trong thực tế?**

1.2 Mục tiêu và câu hỏi nghiên cứu

Mục tiêu của đề tài là phân tích kiến trúc PKI, cơ chế xác thực chứng thư X.509, và xây dựng môi trường lab kiểm chứng điều kiện chấp nhận/từ chối chứng thư cùng vai trò của cơ chế thu hồi.

Đề tài đặt ra ba giả thuyết nghiên cứu chính gắn liền với các câu hỏi nghiên cứu:

- **Giả thuyết H1 (Về tính độc lập giữa chữ ký số và quyết định chấp nhận chứng thư):** Chữ ký số hợp lệ của CA không tự nó bảo đảm chứng thư được chấp nhận. Quyết định xác minh còn phụ thuộc vào các điều kiện kiểm tra được thực thi tại client, bao gồm việc xây dựng chuỗi tin cậy về Trust Anchor, kiểm tra thời hạn hiệu lực, danh tính máy chủ (SAN), mục đích sử dụng (EKU) và trạng thái thu hồi. Giả thuyết này gắn liền với RQ2 và được kiểm chứng qua các ca kiểm thử thực nghiệm (TC01–TC08, TC10).
- **Giả thuyết H2 (Về độ trễ và sự phụ thuộc trong cơ chế thu hồi):** Trạng thái tin cậy của chứng thư mang tính thời gian thực và phụ thuộc vào chính sách của client; nếu client không chủ động kích hoạt kiểm tra thu hồi qua danh sách thu hồi (CRL), chứng thư bị thu hồi vẫn vượt qua quy trình thẩm định để được chấp nhận. Giả thuyết này gắn với RQ3 và được kiểm chứng trực tiếp qua ca TC07 (đối chiếu với mốc chuẩn TC01).
- **Giả thuyết H3 (Về chi phí vận hành và tính khả thi triển khai):** Độ phức tạp tính toán và chi phí lưu lượng trong thẩm định đường dẫn có xu hướng tăng theo độ sâu của chuỗi phân cấp và kích thước danh sách thu hồi. Trong phạm vi đề tài, giả thuyết này được phân tích định tính dựa trên các chuẩn RFC (RFC 5280, RFC 6960) và chưa được kiểm chứng thực nghiệm bằng phép đo hiệu năng chuyên biệt.

Để hiện thực hóa mục tiêu và kiểm chứng các giả thuyết, đề tài tập trung giải quyết 4 câu hỏi nghiên cứu:

1. **RQ1:** PKI liên kết danh tính với khóa công khai bằng cách nào?
2. **RQ2:** Những điều kiện nào khiến chứng thư X.509 được chấp nhận hoặc từ chối?
3. **RQ3:** CRL và OCSP giúp giảm thiểu rủi ro liên quan đến chứng thư bị thu hồi như thế nào?
4. **RQ4:** Những điểm yếu nào vẫn tồn tại trong PKI ngay cả khi các thuật toán mật mã vẫn bảo đảm an toàn?

Mối liên hệ giữa các câu hỏi nghiên cứu với các chương trong báo cáo:

- **RQ1** được phân tích qua kiến trúc PKI, mô hình tin cậy và cấu trúc chứng thư X.509 ở Chương 3 và Chương 4.
- **RQ2, RQ3** được đối chiếu giữa lý thuyết thẩm định đường dẫn, thu hồi (Chương 4) và kiểm chứng qua 10 ca kiểm thử (TC01–TC10) ở Chương 6.
- **RQ4** được phân tích qua mô hình đe dọa, giới hạn chữ ký ở Chương 5 và hướng phát triển (CT, ACME) ở Chương 7.

1.3 Phạm vi và phương pháp nghiên cứu

Phạm vi nghiên cứu: Đề tài tập trung vào mô hình PKI phân cấp X.509 v3 và xác thực máy chủ TLS trong môi trường lab, gồm cấu trúc trường/extension then chốt (SAN, Basic Constraints, Key Usage), thuật toán xác minh chuỗi tin cậy, cơ chế thu hồi (CRL/OCSP) và mô hình đe dọa.

Phương pháp nghiên cứu: Kết hợp nghiên cứu chuẩn quốc tế (RFC 5280 [5], RFC 6960 [6], RFC 8446 [3], RFC 3647 [7]) với thực nghiệm: thiết lập mô hình PKI đa cấp bằng OpenSSL và thực thi 10 ca kiểm thử (TC01–TC10) đối chiếu với lý thuyết. Các kết quả thực nghiệm được giới hạn trong môi trường PKI nội bộ được xây dựng bằng OpenSSL. Những nhận định về OCSP, hiệu năng ở quy mô lớn và hoạt động của các CA công cộng được phân tích trên cơ sở tài liệu tham khảo và chuẩn kỹ thuật, không được xem là kết quả thực nghiệm trực tiếp của đề tài.

Giới hạn ngoài phạm vi (Out of Scope): Đề tài không triển khai dịch vụ OCSP trực tuyến (chỉ phân tích lý thuyết, thực nghiệm tập trung vào CRL); không dùng phần cứng HSM (khóa CA lưu trữ dạng tệp tin phục vụ học thuật); không đo lường hiệu năng hay tải mạng quy mô lớn; và không mô phỏng quy trình kiểm toán pháp lý theo WebTrust/ETSI của các CA thương mại.

1.4 Cấu trúc của báo cáo

Báo cáo được bố cục thành 7 chương chuyên môn và phần kết luận:

- **Chương 1 – Giới thiệu:** Bối cảnh, phân tích MITM, vai trò PKI, mục tiêu, giả thuyết H1–H3, câu hỏi RQ1–RQ4 và phương pháp nghiên cứu.
- **Chương 2 – Cơ sở mật mã:** Mật mã bất đối xứng, hàm băm, chữ ký số, vòng đời khóa và các lớp thuật toán trong TLS 1.3.
- **Chương 3 – Kiến trúc PKI:** Cấu trúc phân cấp PKI, mô hình tin cậy, vòng đời chứng thư và chính sách vận hành CP/CPS (RFC 3647).
- **Chương 4 – X.509 và xác thực:** Cấu trúc chứng thư X.509 v3, thuật toán thẩm định đường dẫn và cơ chế thu hồi qua CRL và OCSP.
- **Chương 5 – Phân tích bảo mật:** Mô hình đe dọa, so sánh mô hình tin cậy và giới hạn an ninh của chữ ký qua sự cố DigiNotar.

- **Chương 6 – Đánh giá thực nghiệm:** Thiết kế lab OpenSSL, kết quả thực nghiệm 10 ca kiểm thử (TC01–TC10) và thảo luận chuyên sâu.
- **Chương 7 – Ứng dụng và xu hướng:** Ứng dụng thực tế, Certificate Transparency, giao thức ACME và định hướng hậu lượng tử.
- **Kết luận và hướng phát triển:** Tổng kết các đóng góp, giải đáp câu hỏi nghiên cứu, nêu rõ hạn chế và hướng mở rộng.

Chương 2

Cơ sở mật mã khóa công khai và PKI

2.1 Yêu cầu bảo mật và quản lý khóa

2.1.1 Yêu cầu bảo mật trong truyền thông và vai trò của PKI

Trong an toàn thông tin, việc bảo vệ luồng truyền thông và dữ liệu giao dịch xoay quanh các mục tiêu an ninh cơ bản (mô hình CIA mở rộng): tính bí mật (confidentiality), tính toàn vẹn (integrity), tính xác thực (authenticity), tính sẵn sàng (availability) và tính chống chối bỏ (non-repudiation). Là hạ tầng quản trị niềm tin và định danh số, PKI hỗ trợ xác thực danh tính thông qua chứng thư X.509 và chuỗi tin cậy, đồng thời chữ ký số của CA hỗ trợ kiểm tra tính toàn vẹn và nguồn gốc của dữ liệu được chứng thực. Cần lưu ý rằng tính chống chối bỏ không thể suy ra thuần túy từ tính hợp lệ của thuật toán ký số, mà còn phụ thuộc chặt chẽ vào quy trình quản trị khóa bí mật, kiểm soát vận hành và bối cảnh pháp lý. Đối với tính bí mật và tính sẵn sàng, PKI không tự đảm nhiệm mà đòi hỏi sự kết hợp với các giao thức truyền thông an toàn (như thỏa thuận khóa ECDHE và mã hóa AEAD trong TLS 1.3 [3]) cùng hạ tầng phân tán (như OCSP Stapling, CDN). Mật mã cung cấp các công cụ toán học nền tảng, còn PKI cung cấp cơ chế liên kết khóa công khai với danh tính thực tế và quản lý niềm tin; sự phân định này sẽ được làm rõ ở Chương 3 và Chương 4. Phạm vi hỗ trợ của PKI được tóm tắt tại Bảng 2.1.

2.1.2 Nguyên lý quản lý khóa và vòng đời khóa mật mã

Theo nguyên lý Kerckhoffs, độ an toàn của hệ thống mật mã phụ thuộc vào sự an toàn của khóa. Khóa công khai (PK) đòi hỏi tính toàn vẹn và xác thực nguồn gốc (do chứng thư PKI bảo chứng); còn khóa bí mật (SK) đòi hỏi tính bí mật tuyệt đối, nếu lộ thì toàn bộ bảo đảm an ninh đều sụp đổ. Quản lý khóa (Key Management) kiểm soát cặp khóa qua 5 giai đoạn vòng đời:

1. **Khởi tạo khóa (Generation):** Sử dụng bộ sinh số ngẫu nhiên giả an toàn mật mã (CSPRNG) và tuân thủ độ dài khóa khuyến nghị (RSA $\geq$ 2048-bit, ECC $\geq$ 256-bit) để chống thám mã vét cạn.

2. **Lưu trữ và bảo vệ khóa bí mật (Storage):** Đối với các hệ thống PKI có yêu cầu an toàn cao, sử dụng mô-đun phần cứng an toàn (HSM) để bảo vệ khóa riêng của CA với cơ chế phân quyền ngưỡng m-trên-n là biện pháp thực hành được khuyến

Mục tiêu an ninh	Vai trò của PKI	Cơ chế thực hiện / Phối hợp
Xác thực (Authenticity)	Hỗ trợ trực tiếp	Chứng thư số X.509, chữ ký số của CA trên Subject PublicKey.
Toàn vẹn (Integrity)	Hỗ trợ trực tiếp	Hàm băm mật mã và chữ ký số trên cấu trúc chứng thư.
Chống chối bỏ (Non-repudiation)	Hỗ trợ trực tiếp	Chữ ký số gắn liền với khóa bí mật duy nhất của thực thể.
Bí mật (Confidentiality)	Kết hợp bên ngoài	Giao thức TLS bắt tay thỏa thuận khóa phiên (ECDHE) và mã hóa đối xứng (AES-GCM).
Sẵn sàng (Availability)	Kết hợp bên ngoài	Hạ tầng mạng phân tán, bộ đệm chứng thực, OCSP Stapling, CDN.

Bảng 2.1: Phân định phạm vi hỗ trợ của PKI đối với các mục tiêu an ninh thông tin.

nghị mạnh. Tuy nhiên, việc sử dụng HSM không phải điều kiện phổ quát mang tính cú pháp để mọi chứng thư X.509 đều hợp lệ, mà phụ thuộc vào chính sách và môi trường triển khai (trong lab thực nghiệm của đề tài, khóa CA được lưu dưới dạng tệp tin cục bộ nhằm phục vụ nghiên cứu học thuật, xem Mục 3.3.5).

3. **Phân phối và chứng thực (Distribution):** Khóa công khai được đóng gói trong yêu cầu cấp chứng thư (CSR) và gửi tới CA để thẩm định, cấp phát chứng thư X.509.

4. **Thời hạn sử dụng an toàn của khóa (Cryptoperiod):** Khóa cần được ấn định Cryptoperiod nhằm giới hạn khối lượng bản mã tích lũy và hạn chế rủi ro thỏa hiệp khóa theo thời gian. Cần phân biệt Cryptoperiod (vòng đời mật mã của khóa) với thời hạn hiệu lực chứng thư (Certificate Validity xác định bởi `notBefore` và `notAfter`), vốn là khoảng thời gian CA cam kết bảo chứng danh tính (Mục 3.2).

5. **Thu hồi và tiêu hủy (Revocation & Destruction):** Khi khóa bí mật nghi ngờ bị lộ, chủ sở hữu phải lập tức yêu cầu thu hồi chứng thư qua CRL/OCSP. Khi hết vòng đời, khóa bí mật phải bị xóa hủy an toàn (zeroize) để ngăn phục hồi dữ liệu.

2.2 Khóa công khai, hàm băm và chữ ký số

Để phân tích cơ chế hoạt động của PKI, cần phân định rành mạch giữa các nguyên hàm mật mã cơ sở:

- **Cặp khóa công khai và khóa bí mật (PK, SK):** Trong mật mã bất đối xứng, mỗi thực thể sở hữu cặp khóa có quan hệ toán học chặt chẽ. Khóa công khai (PK) được phổ biến rộng rãi, còn khóa bí mật (SK) do chủ sở hữu lưu giữ bí mật. Cặp khóa thuần túy là giá trị nhị phân toán học, không tự chứa hay chứng minh danh tính thực tế của chủ thể.

- **Hàm băm mật mã (H):** Ánh xạ thông điệp m có kích thước tùy ý thành giá trị tóm lược (digest) cố định: $h = H(m)$. Hàm băm chuẩn phải thỏa mãn ba tính chất: kháng tiền ảnh, kháng tiền ảnh thứ hai và kháng va chạm (collision resistance). Dù đảm bảo tính toàn vẹn dữ liệu, hàm băm không thể xác thực nguồn gốc thông điệp vì không chứa yếu tố bí mật.

- **Chữ ký số (Digital Signature):** Kết hợp hàm băm và mật mã khóa công khai để bảo đảm tính toàn vẹn, xác thực nguồn gốc và chống chối bỏ qua cặp thuật toán:

$$\sigma = \text{Sign}(SK, H(m)) \tag{2.1}$$

$$\text{Verify}(PK, H(m), \sigma) \in \{\text{True}, \text{False}\} \tag{2.2}$$

  Trong thực tế, chuẩn cổ điển RSA PKCS#1 v1.5 dùng đệm tất định, còn RSA-PSS dùng đệm xác suất với muối ngẫu nhiên (salt) chống tấn công đại số. Với Ed25519, ở chế độ PureEdDSA (RFC 8032), thuật toán ký trực tiếp trên thông điệp m và băm nội tại bằng SHA-512, không đòi hỏi bước băm $H(m)$ riêng biệt từ bên ngoài.

- **Chứng thư số (Digital Certificate):** Chữ ký số chỉ chứng minh thông điệp tạo bởi người giữ SK tương ứng, không định danh thực thể ngoài đời thực. Chứng thư X.509 đóng gói khóa công khai PK cùng định danh chủ thể (Subject) và được CA xác thực bằng chữ ký số với khóa bí mật SK_{CA}, hoàn thiện mối liên kết tin cậy (binding) giữa danh tính và khóa công khai.

Từ góc độ kiểm tra an ninh, cần phân biệt rạch ròi ba cấp độ thẩm định:

1. **Chữ ký số hợp lệ:** Nội dung thông điệp khớp hoàn toàn với chữ ký và khóa công khai dùng xác minh về mặt toán học.
2. **Chứng thư số được chấp nhận:** Bên cạnh chữ ký hợp lệ, chứng thư còn phải thỏa mãn chuỗi tin cậy tới Trust Anchor, thời hạn hiệu lực, danh tính máy chủ (SAN), mục đích sử dụng (EKU) và chính sách client.
3. **Trạng thái thu hồi:** Chứng thư không nằm trong danh sách thu hồi (CRL) hoặc phản hồi OCSP tại thời điểm kiểm tra.

Sự phân biệt này là nền tảng trực tiếp để kiểm chứng giả thuyết H_1, H_2 qua bộ ca kiểm thử tại Chương 6.

Bản chất kỹ thuật và giới hạn của các thành phần mật mã được đối chiếu tại Bảng 2.2.

2.3 Vai trò thuật toán trong TLS

Trong các hệ thống bảo mật hiện đại như TLS 1.3 (RFC 8446 [3]), các thuật toán mật mã không mã hóa trực tiếp dữ liệu bằng khóa công khai của chứng thư mà được phân công độc lập theo ba lớp chức năng:

- **Lớp xác thực (Authentication Layer):** Trong bắt tay TLS 1.3, máy chủ gửi chứng thư X.509 và thông điệp `CertificateVerify` được ký bởi khóa bí mật dài hạn SK_{server} trên toàn bộ transcript bắt tay. Thao tác này chứng minh máy chủ sở hữu khóa bí mật tương ứng (Proof of Possession), nhưng không chứng minh được chứng thư có bị CA cấp sai hay không nếu CA bị xâm nhập. Khóa này không dùng để mã hóa dữ liệu.

Bảng 2.2: So sánh bản chất và vai trò của các thành phần mật mã trong PKI

Khái niệm	**Bản chất kỹ thuật**	**Khóa bí mật (SK)**	**Giá trị an ninh cung cấp**	**Hạn chế nội tại**
Cặp khóa (PK, SK)	Hai khóa có liên hệ toán học; PK công khai, SK bảo mật.	Chỉ duy nhất chủ sở hữu hợp pháp nắm giữ và bảo vệ.	Nền tảng cho ký số, xác thực sở hữu và thỏa thuận khóa phiên.	Không tự liên kết được với danh tính thực thể ngoài đời thực.
Hàm băm (H)	Ánh xạ thông điệp tùy ý thành digest có độ dài cố định.	Không sử dụng khóa.	Bảo đảm tính toàn vẹn, tóm lược dữ liệu, kháng va chạm.	Không xác thực nguồn gốc do bất kỳ ai cũng tính toán được.
Chữ ký số	Cặp thuật toán Sign/Verify thao tác trên giá trị băm thông điệp.	Ký bằng SK của chủ thể; kiểm tra bằng PK tương ứng.	Xác thực nguồn gốc dữ liệu, bảo đảm tính toàn vẹn và chống chối bỏ.	Chỉ xác minh tính hợp lệ của dữ liệu với PK, không định danh người ký.
Chứng thư số	Cấu trúc dữ liệu liên kết PK với danh tính, được CA ký.	Ký bởi SK_{CA}; cấu trúc chứng thư không bao giờ chứa SK.	Thiết lập liên kết tin cậy giữa khóa công khai và danh tính chủ thể.	Phụ thuộc độ tin cậy của CA, thời hạn hiệu lực và trạng thái thu hồi.

- **Lớp thỏa thuận khóa phiên (Key Exchange Layer):** TLS 1.3 loại bỏ hoàn toàn trao đổi khóa RSA tĩnh, bắt buộc dùng Diffie-Hellman tạm thời (ECDHE như X25519 hoặc DHE), ngoại trừ chế độ chỉ dùng khóa chia sẻ trước (PSK-only). Cặp khóa tạm thời được sinh ngẫu nhiên mỗi phiên và bị hủy ngay sau bắt tay, mang lại tính bí mật chuyển tiếp hoàn hảo (Perfect Forward Secrecy - PFS) giúp ngăn giải mã hồi cứu nếu khóa máy chủ bị lộ sau này.

- **Lớp mã hóa dữ liệu ứng dụng (Record Layer):** Khóa phiên đối xứng được suy dẫn từ giá trị bí mật chung qua HKDF. Tầng Record sử dụng độc quyền các thuật toán mã hóa đối xứng có xác thực AEAD (AES-128-GCM, AES-256-GCM, ChaCha20-Poly1305) để bảo đảm đồng thời tính bí mật và toàn vẹn cho dữ liệu ứng dụng với hiệu năng tối ưu.

Sự phân định vai trò các thuật toán trong TLS 1.3 được tổng hợp tại Bảng 2.3.

Bảng 2.3: Phân định vai trò các thuật toán mật mã trong giao thức TLS 1.3

Lớp chức năng	**Thuật toán tiêu biểu**	**Khóa mật mã sử dụng**	**Mục tiêu an ninh đáp ứng**
Xác thực (Authentication)	RSA-PSS, ECDSA (secp256r1), Ed25519.	Khóa bất đối xứng dài hạn (PK, SK) trong chứng thư X.509.	Xác thực nguồn gốc máy chủ, ngăn chặn tấn công mạo danh và người đứng giữa (MITM).
Thỏa thuận khóa (Key Exchange)	ECDHE (X25519, secp256r1), DHE.	Cặp khóa bất đối xứng tạm thời (ephemeral), sinh mới mỗi phiên.	Thiết lập bí mật chung an toàn; bảo đảm Bí mật chuyển tiếp hoàn hảo (PFS).
Mã hóa dữ liệu (Record Layer)	AEAD (AES-128-GCM, AES-256-GCM, ChaCha20-Poly1305).	Khóa đối xứng phiên (Session Key) suy dẫn qua HKDF.	Bảo đảm tính bí mật và toàn vẹn dữ liệu ứng dụng với tốc độ và hiệu năng tối ưu.

Trong báo cáo này, TLS là bối cảnh ứng dụng thực tế của chứng thư máy chủ; trọng tâm nghiên cứu và thực nghiệm của đề tài không nhằm so sánh hiệu năng của các thuật toán mật mã, mà tập trung kiểm chứng các điều kiện logic khiến chứng thư máy chủ được chấp nhận hoặc bị từ chối theo chuẩn RFC 5280 và RFC 8446.

Chương 3

Kiến trúc PKI và vòng đời chứng thư

3.1 Thành phần và mô hình tin cậy

Hạ tầng khóa công khai (Public Key Infrastructure – PKI) là hệ thống tích hợp gồm phần cứng, phần mềm, quy trình, nhân sự và chính sách quản lý nhằm tạo lập, lưu trữ, phân phối và thu hồi chứng thư số theo chuẩn ITU-T X.509 (chuẩn hóa tại RFC 5280 [5] và khung chính sách RFC 3647 [7]). Về bản chất, PKI giải quyết bài toán niềm tin phân tán trên mạng mở bằng cách chuyển dịch việc tin cậy lẫn nhau giữa các đối tượng ngang hàng sang việc cùng đặt niềm tin vào bên thứ ba có thẩm quyền (Trusted Third Party).

3.1.1 Các thành phần cốt lõi trong PKI

Một hệ thống PKI hoàn chỉnh bao gồm các cấu phần chức năng phối hợp chặt chẽ trong quản lý và duy trì chuỗi tin cậy:

- **Gốc tin cậy (Trust Anchor):** Là mốc khởi đầu của niềm tin mà relying party chấp nhận vô điều kiện trong Trust Store cục bộ. Trong thực tế, Trust Anchor thường là khóa công khai của Root CA tích hợp sẵn trong hệ điều hành hoặc trình duyệt.
- **Tổ chức chứng thực gốc (Root CA):** Thực thể đứng ở đỉnh mô hình phân cấp, sở hữu cặp khóa tối cao và tự cấp chứng thư tự ký (Issuer trùng Subject). Khóa bí mật (SK_{Root}) thường được duy trì ngoại tuyến (offline) trong HSM để triệt tiêu nguy cơ tấn công qua mạng.
- **Tổ chức chứng thực trung gian (Intermediate CA / Sub-CA):** Được Root CA ủy quyền để vận hành cấp phát chứng thư hàng ngày cho thực thể cuối và phát hành CRL. Đóng vai trò lớp cách ly rủi ro (risk isolation), cho phép thu hồi độc lập khi xảy ra sự cố mà không ảnh hưởng đến cây tin cậy của Root CA.
- **Cơ quan đăng ký (Registration Authority – RA):** Giao diện tiếp nhận và thẩm tra danh tính hoặc quyền sở hữu tên miền của đối tượng yêu cầu trước khi chuyển cho CA ký. RA không trực tiếp ký chứng thư và không được nắm giữ khóa bí mật của CA.
- **Thực thể cuối (End-entity) và Chủ thể (Subject):** Subject là định danh đóng gói trong chứng thư, còn End-entity là vai trò tầng lá (máy chủ TLS, người dùng)

sở hữu cặp khóa và không có quyền cấp chứng thư cho bên khác. Phần mở rộng `basicConstraints` của End-entity có thể vắng mặt hoặc phải có cờ `cA:FALSE`.

- **Bên tin cậy (Relying Party / Client):** Thực thể hoặc ứng dụng tiếp nhận chứng thư số và tự đưa ra quyết định chấp nhận hay từ chối dựa trên Trust Store cục bộ cùng chính sách kiểm tra của riêng mình. Cần nhấn mạnh rằng việc CA ký phát hành không đồng nghĩa với việc mọi client đều phải tự động tin cậy chứng thư đó; quyền quyết định tối hậu thuộc về relying party.
- **Kho lưu trữ và công bố (Repository / Directory Service):** Hệ thống dịch vụ mạng (HTTP/LDAP) lưu trữ và xuất bản chứng thư CA, danh sách thu hồi (CRL) hoặc phản hồi OCSP để bên tin cậy truy vấn trạng thái.

Bảng 3.1 tổng hợp vai trò, loại khóa quản lý và trạng thái hoạt động của các thành phần trong hệ thống PKI.

Thành phần	**Khóa quản lý**	**Trạng thái vận hành**	**Chức năng chính**
Trust Anchor	Khóa công khai Root CA	Tích hợp sẵn trong OS/Browser	Điểm mốc tin cậy tuyệt đối để neo chuỗi xác minh.
Root CA	SK_{Root}, PK_{Root}	Ngoại tuyến (Offline, HSM)	Ký phát hành chứng thư tự ký và ủy quyền cho Sub-CA.
Intermediate CA	SK_{Sub}, PK_{Sub}	Trực tuyến (Online)	Ký phát hành chứng thư cho End-entity, ký danh sách CRL.
RA	Khóa xác thực danh tính	Trực tuyến	Thẩm tra định danh, duyệt yêu cầu trước khi gửi sang CA.
Chủ thể (Subject)	SK_{Entity}, PK_{Entity}	Trực tuyến (Web/Client)	Nắm giữ khóa bí mật, dùng chứng thư để chứng minh danh tính.
Bên tin cậy (RP)	Sở hữu Trust Store	Trực tuyến (Client)	Thẩm định đường dẫn chứng thư, kiểm tra trạng thái thu hồi.
Kho lưu trữ (Repo)	Không giữ khóa ký	Trực tuyến (HTTP, LDAP)	Lưu trữ, xuất bản chứng thư CA, CRL và dịch vụ OCSP.

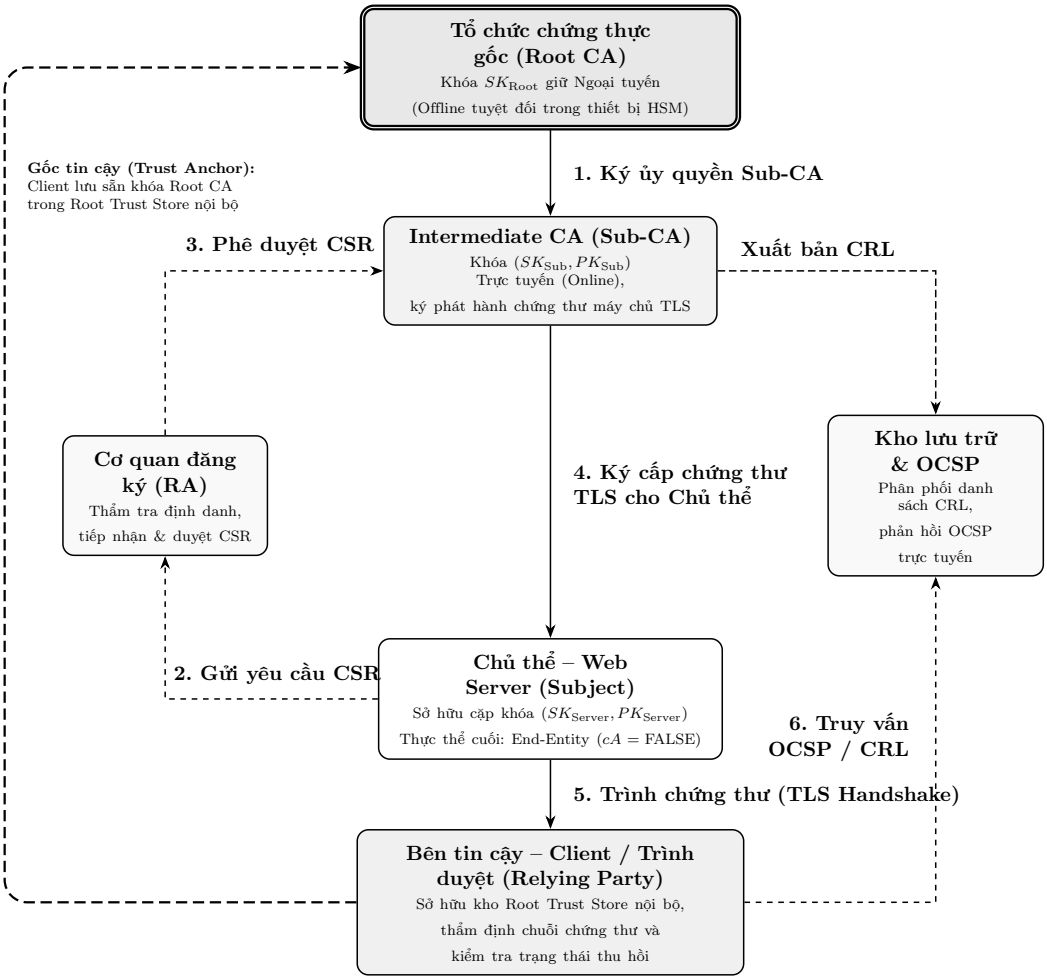
Bảng 3.1: Tổng hợp vai trò và đặc điểm vận hành của các thành phần trong PKI.

3.1.2 Mô hình tin cậy phân cấp (Hierarchical Trust Model)

Trong PKI chuẩn ITU-T X.509, mô hình tin cậy chuẩn mực nhất là mô hình cây phân cấp (Hierarchical Tree), trong đó niềm tin được ủy quyền một chiều từ gốc xuống ngọn (Root → Intermediate → Leaf). Mô hình này cho phép phân nhánh CA theo mục đích kỹ thuật chuyên biệt (TLS, Code Signing), đồng thời cô lập rủi ro: bảo vệ Root CA ngoại tuyến và chỉ cần thu hồi nhánh Intermediate CA bị thỏa hiệp mà không làm xáo trộn Root Store toàn cầu.

Trong mô hình lab thực nghiệm của nhóm (Chương 6), các thành phần cốt lõi được triển khai gồm Root CA, Intermediate CA, End-entity (Web Server) và Relying Party (OpenSSL verification client). Các cấu phần như RA hay dịch vụ công bố trực tuyến được tinh giản để tập trung nghiên cứu bản chất giải thuật xác minh chuỗi tin cậy. Các biến thể kiến trúc khác như Chứng nhận chéo (Cross-certification), Cầu nối (Bridge CA) và Mạng lưới tin cậy (Web of Trust) được phân tích đối chiếu tại Mục 5.2 (Chương 5).

Hình 3.1 minh họa tổng thể mối quan hệ tương tác, luồng dữ liệu cấp phát và quy trình xác thực giữa các thành phần trong mô hình PKI phân cấp.



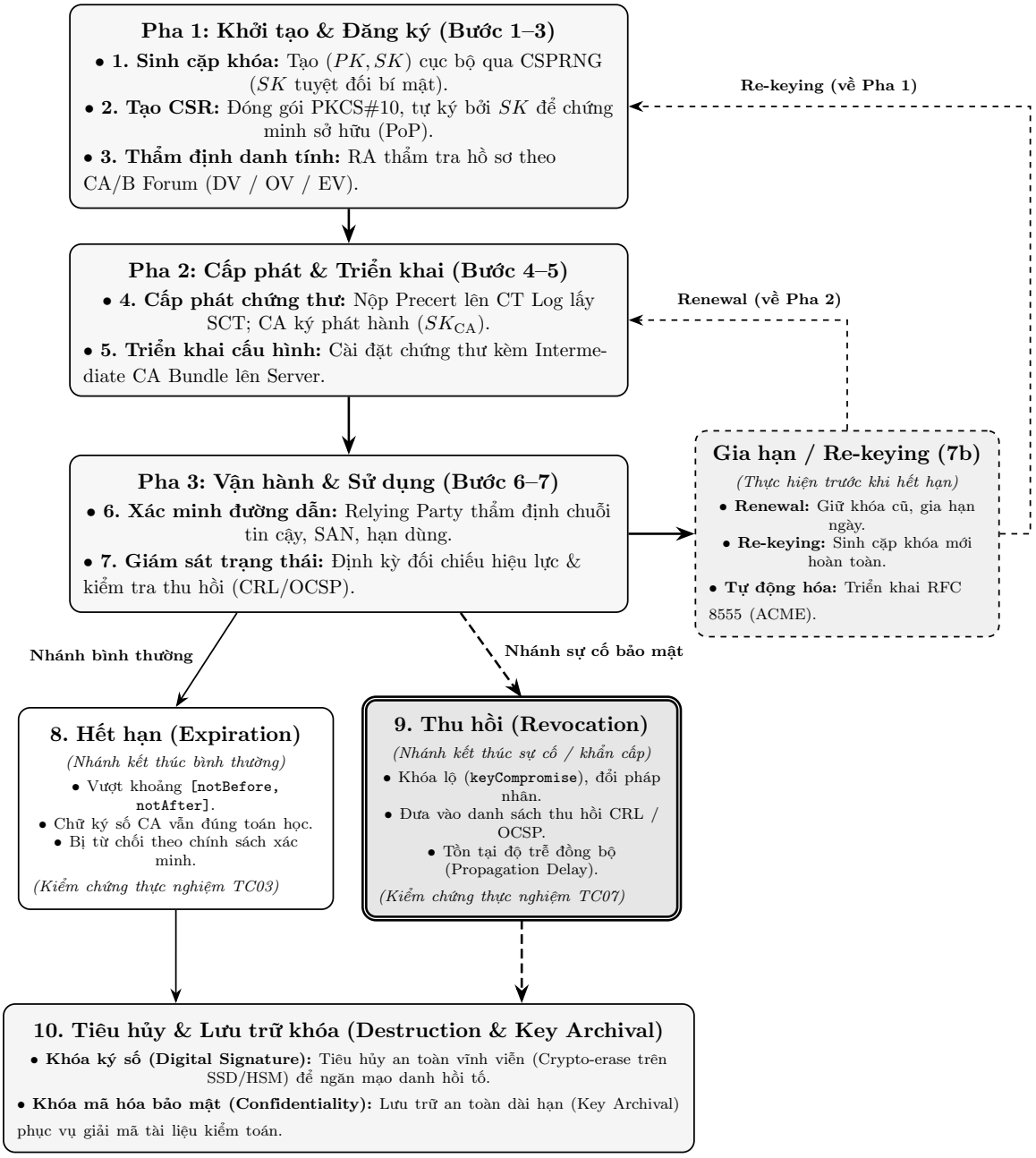
Hình 3.1: Kiến trúc các thành phần và luồng dữ liệu cấp phát, xác thực trong mô hình PKI phân cấp.

3.2 Vòng đời chứng thư

Trong khi Mục 2.1.2 trình bày vòng đời khóa mật mã, Mục 3.2 tập trung vào vòng đời chứng thư số (quản lý trạng thái, cấu trúc dữ liệu và chuỗi tin cậy). Hai vòng đời này tách biệt: chứng thư có thể hết hạn hoặc bị thu hồi trước khi khóa bị tiêu hủy, và khóa có thể tiếp tục dùng qua các thế hệ chứng thư (renewal). Đồng thời, bản thân CA cũng có vòng đời riêng: thay thế khóa (CA Rekey - mục 5.6 của dàn bài RFC 3647 [7]) và ngừng hoạt động (CA Termination - mục 5.8 của dàn bài RFC 3647) theo chính sách vận hành (Mục 3.3).

3.2.1 Các giai đoạn và nhánh rẽ trong vòng đời chứng thư

Vòng đời chứng thư X.509 gồm 10 giai đoạn có các nhánh rẽ và vòng lặp thay thế nhau, được quy hoạch thành 4 pha chính như minh họa trong Hình 3.2.



Hình 3.2: Mô hình các giai đoạn, nhánh rẽ và vòng lặp trong vòng đời chứng thư X.509.

Pha 1: Khởi tạo và đăng ký (Bước 1–3)

1. **Sinh cặp khóa (Key Generation):** Chủ thể (Subject) tự sinh cặp khóa (PK, SK) trên thiết bị cục bộ bằng bộ sinh số ngẫu nhiên an toàn (CSPRNG). Khóa bí mật (SK) được lưu giữ bảo mật, không bao giờ gửi qua mạng cho CA hay bên thứ ba.

2. **Tạo yêu cầu ký chứng thư (CSR Generation):** Chủ thể đóng gói khóa công khai

(PK) cùng thông tin định danh thành tệp CSR (chuẩn RFC 2986/PKCS#10 [8]) và ký bằng SK để chứng minh quyền sở hữu khóa (Proof of Possession – PoP). Cần phân biệt rõ: chữ ký trên CSR chỉ chứng minh bên tạo yêu cầu có khả năng sử dụng khóa riêng tương ứng với khóa công khai trong CSR; điều này hoàn toàn không tự chứng minh người yêu cầu là chủ thể danh tính được khai báo. Việc liên kết khóa với danh tính thực tế phụ thuộc trọn vẹn vào quy trình thẩm tra độc lập của CA/RA ở bước tiếp theo.

3. **Xác minh danh tính (Identity Verification):** Cơ quan đăng ký (RA) thẩm tra danh tính theo Baseline Requirements [9] và CP/CPS theo các mức thẩm định: Domain Validation (DV - kiểm tra quyền kiểm soát tên miền), Organization Validation (OV - xác minh pháp nhân qua cổng đăng ký doanh nghiệp), hoặc Extended Validation (EV - đối chiếu giấy phép và xác minh độc lập theo quy định riêng của CA/B Forum).

Pha 2: Cấp phát và triển khai (Bước 4–5)

4. **Cấp phát chứng thư và cơ chế minh bạch chứng thư (CT):** CA không ký lên toàn bộ tập tin chứng thư mà ký lên cấu trúc dữ liệu tóm lược `TBSCertificate` (RFC 5280 [5]). Trong OpenSSL, nếu không bật chỉ thị `copy_extensions = copy`, chứng thư phát hành sẽ bị thiếu phần mở rộng bắt buộc như SAN và bị trình duyệt từ chối (bẫy kỹ thuật này được đúc kết từ thiết kế lab và đối chứng qua TC01, TC04, TC08 tại Chương 6). Đối với Web PKI, trước khi phát hành chính thức, CA tạo Precertificate nộp lên CT Log (RFC 9162 [10]), nhận lại chứng từ thời gian SCT, nhúng SCT vào phần mở rộng rồi mới ký chính thức; đây là chính sách bắt buộc của Root Store trình duyệt, không thuộc chuẩn RFC 5280 và không phải là bước bắt buộc đối với các PKI nội bộ hay mô hình lab học thuật (xem Mục 7.1).

5. **Cài đặt và triển khai (Installation / Deployment):** Chủ thể cấu hình chứng thư cùng tệp chuỗi chứng thư trung gian (Certificate Bundle) lên máy chủ dịch vụ. Nếu thiếu chứng thư trung gian, client không thể hoàn thành việc xây dựng đường dẫn tin cậy về Trust Anchor (kiểm chứng tại ca TC06, Chương 6).

Pha 3: Vận hành (Bước 6–7)

6. **Xác minh và sử dụng (Validation & Usage):** Khi máy chủ gửi chứng thư trong bắt tay TLS 1.3 [3], relying party kích hoạt thuật toán xác minh đường dẫn: dựng chuỗi về Trust Anchor, kiểm tra chữ ký, Basic Constraints, Key Usage/EKU, khớp SAN và kiểm tra thời hạn cùng thu hồi (chi tiết tại Mục 4.2).

7. **Gia hạn (Renewal / Re-keying):** Chủ thể gia hạn để duy trì kết nối: *Renewal* (giữ nguyên cặp khóa cũ) hoặc *Re-keying* (tạo cặp khóa mới từ Bước 1). Theo Baseline Requirements (v2.3.1) [9], thời hạn tối đa của chứng thư TLS được rút ngắn theo lộ trình: tối đa 200 ngày (từ 15/03/2026), 100 ngày (từ 15/03/2027) và 47 ngày (từ 15/03/2029), thúc đẩy bắt buộc tự động hóa qua ACME (Mục 7.2).

Pha 4: Kết thúc vòng đời (Bước 8–10)

8. **Hết hạn (Expiration):** Chứng thư hết hạn khi thời điểm xác minh nằm ngoài khoảng `[notBefore, notAfter]`. Cần lưu ý rằng chữ ký số của CA trên chứng thư hết hạn vẫn hoàn toàn đúng về mặt toán học; việc từ chối phụ thuộc vào chính sách xác minh và đồng hồ hệ thống của client (minh chứng cho giả thuyết H1, kiểm chứng qua ca TC03).

9. **Thu hồi chứng thư (Revocation):** Nhánh rẽ khẩn cấp khi xảy ra sự cố; CA đưa số sê-ri vào danh sách thu hồi kèm mã lý do chuẩn hóa trên một dòng: `keyCompromise`, `cACompromise`, `affiliationChanged`, `superseded`, `cessationOfOperation`. Việc thu hồi có độ trễ truyền bá (propagation delay): relying party chỉ nhận biết khi tải CRL mới (theo `thisUpdate`/`nextUpdate`) hoặc truy vấn OCSP trực tiếp (phân tích tại Mục 4.3, kiểm chứng qua ca TC07).

10. **Tiêu hủy và lưu trữ khóa (Destruction & Key Archival):** Khóa ký số hết hạn hoặc bị thu hồi phải bị tiêu hủy an toàn (zeroize hoặc crypto-erase trên SSD/HSM) để ngăn khôi phục vật lý. Ngược lại, khóa từng dùng mã hóa dữ liệu lâu dài có thể được lưu trữ an toàn dài hạn (Key Archival) nhằm phục vụ giải mã kiểm toán trong tương lai.

3.2.2 Ánh xạ giai đoạn vòng đời chứng thư với công cụ OpenSSL và kịch bản thực nghiệm

Bảng 3.2 ánh xạ các giai đoạn vòng đời chứng thư X.509 với câu lệnh OpenSSL tương ứng và 10 ca kiểm thử thực nghiệm (TC01–TC10) tại Chương 6.

3.2.3 Phân biệt Yêu cầu ký chứng thư (CSR) và Chứng thư số đã phát hành

Bảng 3.3 đối chiếu bản chất kỹ thuật giữa tệp yêu cầu ký chứng thư (CSR, RFC 2986 [8]) và chứng thư số X.509 v3 (RFC 5280 [5]).

Sau khi được cấp phát, chứng thư X.509 chứa các trường dữ liệu và phần mở rộng (extension) mà client sử dụng trong suốt quá trình thẩm định. Việc CSR hợp lệ về cú pháp và PoP không thay thế cho quy trình kiểm tra chứng thư thực tế, nội dung sẽ được phân tích chi tiết tại Mục 4.1.

3.3 Chính sách vận hành

Một hệ thống PKI không chỉ vận hành bằng thuật toán mật mã mà phụ thuộc cốt lõi vào hệ thống chính sách và quy trình vận hành bảo đảm tin cậy. Khung chuẩn RFC 3647 [7] quy định dàn bài gồm 9 phần lớn định hướng các chủ đề kỹ thuật, an ninh và quản trị cho CA. Cần lưu ý rằng các ký hiệu số mục được dẫn chiếu dưới đây (như mục 5.2, 5.4, 6, 8) là số mục trong dàn bài chuẩn của tài liệu CP/CPS theo RFC 3647, không phải số điều khoản của văn bản RFC 3647. Tiêu chí ràng buộc cụ thể do CA xác định hoặc phải tuân thủ chính sách Root Store và CA/Browser Forum [9].

Giai đoạn vòng đời	Lệnh OpenSSL thực thi trong Lab	Ca kiểm thử liên quan
1. Sinh cặp khóa	`openssl genrsa -aes256 ...` hoặc `openssl ecparam ...`	Nền tảng mọi kịch bản
2. Tạo CSR (PoP)	`openssl req -new -key ... -out ...`	Tạo yêu cầu ký chứng thư kèm PoP
4. Cấp phát chứng thư	`openssl ca -in ... -out ... -extfile ...`	Cấp phát X.509 với extension; TC05 (chữ ký bị sửa đổi bit), TC08 (cấp sai cờ EKU)
5. Triển khai cấu hình	Cấu hình tệp chứng thư và chuỗi Intermediate CA bundle	TC06 (thiếu Intermediate CA bundle)
6. Xác minh đường dẫn	`openssl verify -CAfile ... -untrusted ... -purpose ... -verify_hostname ...`	TC01 (thẩm định thành công toàn diện), TC02 (self-signed không thuộc trust store), TC04 (hostname không khớp SAN), TC08 (sai mục đích EKU), TC10 (CA ngoài trust store)
8. Kiểm tra thời hạn	`openssl verify -attime ...` (hoặc so khớp thời gian thực)	TC03 (thời điểm kiểm tra nằm ngoài hạn hiệu lực)
9. Thu hồi chứng thư	`openssl ca -revoke ...`, `openssl ca -gencrl ...` và xác minh với `-crl_check`	TC07 (chứng thư bị thu hồi đưa vào CRL)

Bảng 3.2: Ánh xạ các giai đoạn vòng đời chứng thư X.509 với lệnh OpenSSL và ca kiểm thử.

3.3.1 Phân định vai trò giữa CP và CPS

Khung RFC 3647 phân định hai tầng chính sách: *Chính sách Chứng thư (CP)* xác định các quy tắc cấp cao về khả năng áp dụng của nhóm chứng thư cho cộng đồng hoặc lớp ứng dụng; còn *Tuyên bố Thực hành Chứng thực (CPS)* đặc tả chi tiết biện pháp kỹ thuật và quy trình thủ tục mà CA áp dụng để hiện thực hóa CP. Theo RFC 5280, CP được định danh trên chứng thư qua OID trong extension `certificatePolicies`. Mục 2.2 của Baseline Requirements [9] yêu cầu tài liệu CP/CPS của CA công cộng phải bám sát cấu trúc dàn bài RFC 3647; trên thực tế các CA thường gộp chung thành tài liệu Combined CP/CPS để tinh giản quản trị. Cần lưu ý rằng trong OpenSSL, chỉ thị `policy = policy_strict` chỉ là quy tắc kỹ thuật đối chiếu trường tên DN, hoàn toàn không phải là một Certificate Policy (CP) theo RFC 3647.

3.3.2 Quản lý và bảo vệ khóa bí mật của CA (Mục 6 của dàn bài RFC 3647)

Mục 6 trong dàn bài RFC 3647 quy định các biện pháp kiểm soát kỹ thuật đối với khóa bí mật của CA. Theo quy định tại Mục 6.2.7 của Baseline Requirements [9], khóa bí mật của Root CA và Intermediate CA bắt buộc phải tạo sinh và lưu trữ trong mô-đun phần

Tiêu chí phân định	Yêu cầu ký chứng thư (CSR – PKCS#10)	Chứng thư số X.509 v3
Bản chất kỹ thuật	Cấu trúc dữ liệu chứa thông tin đề nghị và khóa công khai do chủ thể tự tạo ra.	Cấu trúc dữ liệu có chữ ký số của CA, liên kết định danh với khóa công khai theo quy trình CP/CPS.
Thực thể thực hiện ký	Ký bởi chính khóa bí mật của chủ thể (SK_{subject}).	Ký bởi khóa bí mật của tổ chức cấp phát (SK_{CA}).
Dữ liệu được ký	Thông tin danh tính yêu cầu và trường khóa công khai (`SubjectPublicKeyInfo`).	Cấu trúc dữ liệu chuẩn hóa `TBSCertificate` (To-Be-Signed Certificate) của CA.
Ý nghĩa của chữ ký	Chỉ chứng minh thực thể gửi yêu cầu có nắm giữ khóa bí mật tương ứng (Proof of Possession – PoP); không chứng minh danh tính.	Xác nhận CA đã thẩm định thông tin theo chính sách vận hành và liên kết danh tính với khóa công khai.
Quyết định về Extensions	Chỉ mang tính chất đề xuất từ phía client.	Do CA toàn quyền ấn định hoặc chọn lọc (qua cờ cấu hình như `copy_extensions` trong OpenSSL).
Phạm vi sử dụng	Chỉ dùng để nộp cho CA/RA trong pha đăng ký cấp phát.	Dùng trong giao thức truyền thông (TLS) để relying party xác thực chuỗi tin cậy.

Bảng 3.3: Phân biệt bản chất kỹ thuật giữa Yêu cầu ký chứng thư (CSR – RFC 2986) và Chứng thư số X.509 v3 (RFC 5280).

cứng an toàn (HSM) đạt chuẩn FIPS 140-2/140-3 Level 3 hoặc Common Criteria EAL 4+ trở lên; khóa không bao giờ được xuất ra dưới dạng bản rõ. Nhằm ngăn chặn lạm quyền cá nhân, các CA áp dụng cơ chế kiểm soát nhiều người (Multiperson Control - mục con 6.2.2) với sơ đồ phân mảnh bí mật ngưỡng m-trên-n (như thuật toán Shamir's Secret Sharing, ví dụ yêu cầu 3 trên 5 thẻ khóa vật lý) khi kích hoạt khóa hoặc ký cấp Intermediate CA. Quá trình tạo khóa CA cấp cao phải diễn ra theo một nghi thức chính thức (Key Generation Ceremony) trong phòng an toàn cách ly mạng, có nhân sự giám sát độc lập và lập biên bản kiểm toán.

3.3.3 Phân quyền và các biện pháp kiểm soát thủ tục (Mục 5.2 của dàn bài RFC 3647)

Mục 5.2 trong dàn bài RFC 3647 đặc tả các biện pháp kiểm soát thủ tục (Procedural Controls) nhằm phân định vai trò tin cậy (Trusted Roles) và nguyên tắc tách biệt nhiệm vụ. Thực tiễn công nghiệp thường phân tách thành các vai trò độc lập: Quản trị viên (Administrator - cài đặt, bảo trì hạ tầng), Nhân viên vận hành CA (CA Operator - xác minh hồ sơ, ký phát và thu hồi chứng thư), Cán bộ kiểm toán (Audit Officer - độc lập giám sát và lưu trữ nhật ký an ninh), và Cán bộ an ninh (Security Officer - quản lý an

ninh vật lý và quyền truy cập HSM). CPS bắt buộc quy định nguyên tắc một nhân sự không được kiêm nhiệm các vai trò mâu thuẫn lợi ích (đặc biệt giữa vận hành và kiểm toán), đồng thời áp dụng cơ chế kiểm soát kép (Dual Control) đòi hỏi sự hiện diện của tối thiểu hai cá nhân có thẩm quyền cho các thao tác trọng yếu.

3.3.4 Ghi nhận nhật ký và đánh giá tuân thủ (Mục 5.4 và Mục 8 của dàn bài RFC 3647)

- **Nhật ký kiểm toán (Mục 5.4 của dàn bài RFC 3647):** CPS cần xác định danh mục các sự kiện phải ghi log (khởi động/dừng dịch vụ, truy cập quản trị, tạo khóa, phát hành chứng thư, tạo CRL) kèm nhãn thời gian tin cậy. Dữ liệu nhật ký được khuyến nghị sao lưu định kỳ vào các phân vùng lưu trữ khó sửa đổi hoặc hệ thống thu thập log tập trung được phân quyền độc lập.
- **Đánh giá tuân thủ (Mục 8 của dàn bài RFC 3647):** RFC 3647 liệt kê các chủ đề về tần suất đánh giá, phạm vi kiểm toán và tư cách của tổ chức đánh giá. Theo chính sách quản lý Root Store và quy định của CA/Browser Forum [9], các CA công cộng thực tế phải trải qua các đợt kiểm toán định kỳ bởi các tổ chức kiểm toán độc lập đủ điều kiện theo các chuẩn mực như WebTrust for CA hoặc ETSI EN 319 411.
- **Bài học từ sự cố DigiNotar (Fox-IT, 2012) [4]:** Báo cáo điều tra của Fox-IT [4] cho thấy DigiNotar có trang bị HSM (nCipher netHSM) và khóa CA chỉ được kích hoạt bằng thẻ thông minh kèm mã PIN, nhưng toàn bộ 8 máy chủ quản lý CA đều bị chiếm quyền. Vì vậy kẻ tấn công ký phát được hàng loạt chứng thư giả khi khóa đang ở trạng thái kích hoạt. Dịch vụ ghi nhật ký của phần mềm CA chạy ngay trên các máy bị chiếm, không có máy chủ nhật ký an ninh riêng, và nhật ký đã bị can thiệp, nên sự vắng mặt của bản ghi đáng ngờ không chứng minh được là không có cấp phát trái phép. Mạng nội bộ chia thành 24 phân đoạn và vùng chứa máy chủ CA không truy cập trực tiếp được từ Internet, nhưng các vùng không được mô tả và thực thi chặt, tường lửa có nhiều luật ngoại lệ giữa các phân đoạn; kẻ tấn công khai thác điều này để đi từ máy chủ web ở vùng ngoài vào vùng CA. Có thể rút ra rằng HSM, văn bản chính sách và kiểm toán là điều kiện cần nhưng không đủ; an ninh thực sự phụ thuộc vào việc phân tách mạng, kiểm soát hệ thống điều khiển CA và giám sát kỹ thuật liên tục.

3.3.5 Đối chiếu chính sách CA thực tế và môi trường thực nghiệm của nhóm

Chính sách của CA thực tế không thể đại diện đầy đủ qua các bài lab thực nghiệm. Cần nhấn mạnh rằng, theo điều khoản phạm vi (Scope) của Baseline Requirements (BR) [9], bộ tiêu chuẩn BR không điều chỉnh các hệ thống PKI nội bộ doanh nghiệp mà Root CA không được phân phối mặc định trong Root Trust Store của hệ điều hành và trình duyệt. Các quy định nghiêm ngặt của BR chỉ bắt buộc khi tham gia chương trình Root Store công cộng; do đó môi trường lab của nhóm nằm ngoài phạm vi điều chỉnh này.

Sự khác biệt giữa CA thực tế và môi trường lab của đề tài thể hiện rõ nét qua ba khía cạnh cốt lõi:

- **Bảo vệ khóa bí mật của CA:** Các CA thương mại bắt buộc lưu khóa trong

mô-đun phần cứng an toàn (HSM) đạt chuẩn FIPS 140-2 Level 3 với cơ chế phân quyền ngưỡng; trong khi lab lưu trữ khóa dưới dạng tệp tin mã hóa cục bộ nhằm phục vụ nghiên cứu học thuật.

- **Quy trình xác minh danh tính:** Các CA công cộng phải thực hiện quy trình thẩm tra hồ sơ pháp nhân và quyền kiểm soát tên miền nghiêm ngặt (DV/OV/EV); trong khi lab tập trung thuần túy vào việc kiểm tra hành vi kỹ thuật của thuật toán xác minh chuỗi.
- **Thu hồi và giám sát:** Lab tập trung kiểm tra danh sách thu hồi CRL tĩnh ngoại tuyến (TC07) và không duy trì dịch vụ OCSP responder trực tuyến hay giám sát qua CT Log công khai.

Mô hình lab do đó hữu ích cho việc kiểm chứng các nguyên lý thẩm định đường dẫn theo RFC 5280, nhưng không đại diện đầy đủ cho quy trình vận hành và năng lực phòng vệ của hệ thống PKI thương mại ngoài thực tế. Bảng 3.4 đối chiếu các khía cạnh chính giữa CA công cộng và môi trường lab.

Sự đối chiếu trên khẳng định các ca kiểm thử TC01–TC10 chỉ nhằm quan sát phản ứng của thuật toán xác minh chuỗi trước các điều kiện vi phạm kỹ thuật theo RFC 5280 [5]. Kết quả lab không phản ánh năng lực phòng vệ hay tính tuân thủ quy trình an ninh mạng mà một CA thực tế bắt buộc phải thiết lập.

Chủ đề theo dàn bài RFC 3647	CPS của CA công cộng thường đặc tả	Triển khai trong bài lab thực nghiệm của nhóm
Xác minh danh tính (Mục 3)	Thường đặc tả quy trình thẩm định hồ sơ pháp lý theo phân hạng chứng thư (DV, OV, EV), đối chiếu cơ sở dữ liệu doanh nghiệp và xác minh quyền kiểm soát tên miền.	Bỏ qua hoàn toàn quy trình xác minh thực tế; thông tin chủ thể (Subject DN) được tự gán trực tiếp qua tệp cấu hình hoặc câu lệnh OpenSSL.
Kiểm soát thủ tục & vai trò tin cậy (Mục 5.2)	Thường phân tách các vai trò độc lập (Quản trị viên, Vận hành, Kiểm toán, An ninh); áp dụng cơ chế kiểm soát kép (Dual Control) cho tác vụ nhạy cảm.	Toàn bộ thao tác do nhóm nghiên cứu thực hiện trên một máy trạm, một tài khoản hệ điều hành, không phân tách vai trò.
Nhật ký kiểm toán (Mục 5.4)	Ghi vết tự động các sự kiện an ninh với nhãn thời gian tin cậy; chuyển log về máy chủ tập trung an toàn hoặc phân vùng lưu trữ bất biến.	Chỉ dựa vào tệp văn bản thô `index.txt` và `serial` của OpenSSL; không có cơ chế lưu vết truy cập quản trị hay chống chỉnh sửa log.
Bảo vệ khóa bí mật của CA (Mục 6.2, 6.2.2)	Lưu trữ bắt buộc trong thiết bị HSM đạt chuẩn tối thiểu FIPS 140-2/140-3 Level 3; kích hoạt bằng cơ chế chia sẻ bí mật ngưỡng nhiều người (m-trên-n).	Khóa bí mật của Root CA và Intermediate CA lưu trực tiếp dưới dạng tệp tin phần mềm (`.key`) không đặt mật khẩu (`-nodes`) trên ổ đĩa máy tính, không sử dụng thiết bị phần cứng bảo mật HSM.
Đánh giá tuân thủ (Mục 8)	Định kỳ thực hiện kiểm toán độc lập theo các chuẩn mực quốc tế (WebTrust, ETSI) để duy trì sự tin cậy trên Root Store.	Không có quy trình đánh giá tuân thủ; là hệ thống tự tạo và tự tin cậy cục bộ phục vụ học thuật.
Pháp lý và trách nhiệm (Mục 9)	Quy định rõ về quỹ bảo hiểm rủi ro, cam kết tài chính với bên tin cậy và cơ chế tài phán giải quyết khiếu nại.	Hoàn toàn không phát sinh cam kết pháp lý hay ràng buộc tài chính.

Bảng 3.4: So sánh đối chiếu giữa khung dàn bài RFC 3647, triển khai CA thực tế và bài lab của nhóm.

Chương 4

X.509, chuỗi tin cậy và cơ chế xác thực

4.1 Cấu trúc chứng thư X.509 v3

Chuẩn ITU-T X.509 phiên bản 3 (RFC 5280 [5]) định nghĩa định dạng chứng thư số bằng cú pháp ASN.1 (Abstract Syntax Notation One). Cấu trúc tổng thể của chứng thư X.509 v3 gồm ba trường chính ở cấp cao nhất:

```
Certificate  ::=  SEQUENCE  {
    tbsCertificate       TBSCertificate,
    signatureAlgorithm   AlgorithmIdentifier,
    signatureValue       BIT STRING  }
```

Trong đó:

- `tbsCertificate` (To-Be-Signed Certificate): Khối dữ liệu chứa toàn bộ thông tin định danh và tham số kỹ thuật cần được ký bảo đảm.
- `signatureAlgorithm`: Định danh thuật toán mật mã mà CA sử dụng để tạo chữ ký số (ví dụ: `sha256WithRSAEncryption` hoặc `ecdsa-with-SHA256`).
- `signatureValue`: Giá trị chữ ký số thực tế (chuỗi bit `BIT STRING`) do CA tính toán trên cấu trúc `tbsCertificate` mã hóa theo quy tắc chuẩn hóa DER. Việc sửa đổi dù chỉ một bit trên chứng thư đã phát hành sẽ phá hủy tính hợp lệ toán học của chữ ký và bị từ chối ngay lập tức (phép thử tính toàn vẹn này được kiểm chứng tại ca kiểm thử TC05).

Khối `tbsCertificate` là đối tượng cốt lõi phản ánh toàn bộ nội dung quản trị và kỹ thuật của chứng thư. Theo Mục 4.1 và 4.2 của RFC 5280 [5], các trường chuẩn và phần mở rộng thiết yếu bao gồm:

4.1.1 Các trường dữ liệu chuẩn (Standard Fields)

- **Số sê-ri (Serial Number):** Số nguyên dương duy nhất do CA gán cho mỗi chứng thư ban hành, độ dài không quá 20 octet theo RFC 5280 (Mục 4.1.2.2). Để chống

tấn công va chạm (collision) trên hàm băm, theo BR [9], CA công cộng phải sinh serial có ít nhất 64 bit ngẫu nhiên thay vì sử dụng cơ chế tăng tuần tự đơn giản.

- **Tên đơn vị cấp phát (Issuer):** Định danh CA đã ký và phát hành chứng thư dưới dạng Tên phân biệt (Distinguished Name – DN) theo chuẩn X.500, gồm chuỗi các thuộc tính như Quốc gia (C), Tổ chức (O), Tên phổ biến (CN). Đối với chứng thư tự ký của Root CA, trường `issuer` trùng khớp hoàn toàn với trường `subject`.
- **Thời hạn hiệu lực (Validity):** Xác định khoảng thời gian mà CA cam kết duy trì thông tin trạng thái chứng thư, xác định bởi cặp mốc `notBefore` và `notAfter` (dùng `UTCTime` trước năm 2050 và `GeneralizedTime` từ năm 2050 trở đi). Thuật toán xác minh yêu cầu kiểm tra thời điểm xác minh nằm trong khoảng này; kết quả phụ thuộc chính sách của client (kiểm chứng tại ca kiểm thử TC03).
- **Tên chủ thể (Subject):** Định danh thực thể sở hữu khóa công khai bên trong chứng thư dưới dạng DN. RFC 5280 cho phép Subject rỗng khi danh tính nằm hoàn toàn trong SAN (khi đó SAN phải critical); chứng thư TLS hiện đại định danh tên máy chủ chủ yếu qua SAN.
- **Thông tin khóa công khai của chủ thể (Subject Public Key Info):** Chứa khóa công khai thực tế của chủ thể cùng mã OID định danh thuật toán và các tham số toán học liên quan (như modulus N, số mũ e của RSA, hoặc định danh đường cong elip của ECDSA). Trường này cho phép relying party trích xuất đúng khóa và thuật toán để xác thực chữ ký của chủ thể mà không cần biết trước cấu hình.

4.1.2 Các phần mở rộng X.509 v3 quan trọng (Standard Extensions)

Phần mở rộng v3 cho phép bổ sung các thuộc tính kiểm soát chính sách và bảo mật linh hoạt. Cấu trúc ASN.1 chuẩn của mỗi phần mở rộng gồm:

```
Extension ::= SEQUENCE {
    extnID      OBJECT IDENTIFIER,
    critical    BOOLEAN DEFAULT FALSE,
    extnValue   OCTET STRING }
```

Mỗi extension gồm mã định danh (`extnID`), cờ `critical` và giá trị dữ liệu (`extnValue`). Nếu `critical: TRUE`, validator bắt buộc phải nhận diện và xử lý extension đó; nếu không hiểu, validator bắt buộc phải từ chối chứng thư. Các phần mở rộng cốt lõi bao gồm:

- **Subject Alternative Name (SAN – OID `2.5.29.17`):** Cho phép gán thêm nhiều danh tính cho chủ thể dưới các định dạng như tên miền (`dNSName`) hoặc địa chỉ IP (`iPAddress`). Các client hiện đại đối chiếu tên máy chủ với SAN, không dựa vào CN (kiểm chứng tại ca kiểm thử TC04).
- **Ràng buộc cơ bản – Basic Constraints (OID `2.5.29.19`):** Xác định thực thể có quyền đóng vai trò CA để ký cấp chứng thư hay không qua cờ `cA` và giới hạn độ sâu tùy chọn `pathLenConstraint`. Chứng thư CA phải có extension này và phải critical (RFC 5280 mục 4.2.1.9). Thực thể cuối có thể không có extension này hoặc có `cA:FALSE`; extension tự nó không ngăn chặn, mà validator từ chối dùng chứng

thư `cA:FALSE` làm CA (ràng buộc này ảnh hưởng trực tiếp đến việc xây dựng chuỗi ở ca TC06).

- **Mục đích sử dụng khóa – Key Usage (OID `2.5.29.15`):** Chuỗi bit giới hạn các thao tác mật mã cơ sở của khóa công khai (như `digitalSignature`, `keyCertSign`, `cRLSign`), thường đặt `critical: TRUE` để ngăn ngừa dùng một khóa cho các ngữ cảnh mâu thuẫn. Cần lưu ý rằng `keyEncipherment` không cần cho TLS 1.3/ECDHE (chỉ cần `digitalSignature`).
- **Mục đích sử dụng khóa mở rộng (EKU – OID `2.5.29.37`):** Xác định giao thức ứng dụng cấp cao mà khóa được áp dụng qua danh sách OID, tiêu biểu như `serverAuth` (xác thực máy chủ TLS) hoặc `codeSigning` (ký mã nguồn). Kết nối TLS máy chủ bị từ chối theo chính sách xác minh khi EKU có mặt mà không chứa `serverAuth` (kiểm chứng tại ca TC08). Chứng thư không có EKU thường không bị giới hạn mục đích.

4.1.3 Trích xuất thực tế cấu trúc chứng thư trong môi trường Lab

Dưới đây là kết quả giải mã cấu trúc chi tiết của chứng thư máy chủ TLS (`server-a.crt`) được cấp bởi Intermediate CA trong môi trường lab bằng lệnh:

```
$ openssl x509 -in demo/out/servers/server-a.crt -text -noout
```

Phân tích từ kết quả thực nghiệm:

Từ kết quả trích xuất trên Hình 4.1, các trường cấu trúc của chứng thư máy chủ phản ánh đúng các thiết lập chính sách đã nghiên cứu:

- **Phiên bản và Số sê-ri:** Chứng thư mang phiên bản `3 (0x2)` cho phép sử dụng các extension v3, và số sê-ri `4096 (0x1000)` được quản lý trong cơ sở dữ liệu `index.txt` của Intermediate CA.
- **Cặp định danh Issuer và Subject:** Thể hiện rõ mô hình phân tầng: `Issuer` trỏ về `CN = Lab Intermediate CA`, còn `Subject` định danh máy chủ dịch vụ `CN = server-a.test`.
- **SAN:** Chỉ định tên miền hợp lệ `DNS:server-a.test`, đáp ứng yêu cầu đối chiếu tên máy chủ của client (đối chứng với ca kiểm thử TC04).
- **Basic Constraints:** Thiết lập `critical, CA:FALSE`, định vị đây là chứng thư thực thể cuối (End-entity) và không có quyền ký phát chứng thư phái sinh.
- **Key Usage và EKU:** Bật `Digital Signature`, `Key Encipherment`; `EKU` kích hoạt `serverAuth`, đáp ứng điều kiện xác thực máy chủ TLS (đối chứng ca TC08).
- **Định danh khóa (SKI và AKI):** Trường SKI và AKI chứa mã băm nhận diện khóa công khai của máy chủ và của Intermediate CA, hỗ trợ thuật toán xây dựng và neo chuỗi tin cậy.



Hình 4.1: Kết quả thực thi lệnh trích xuất cấu trúc chứng thư X.509 v3 của máy chủ TLS (`server-a.crt`) trong môi trường thực nghiệm.

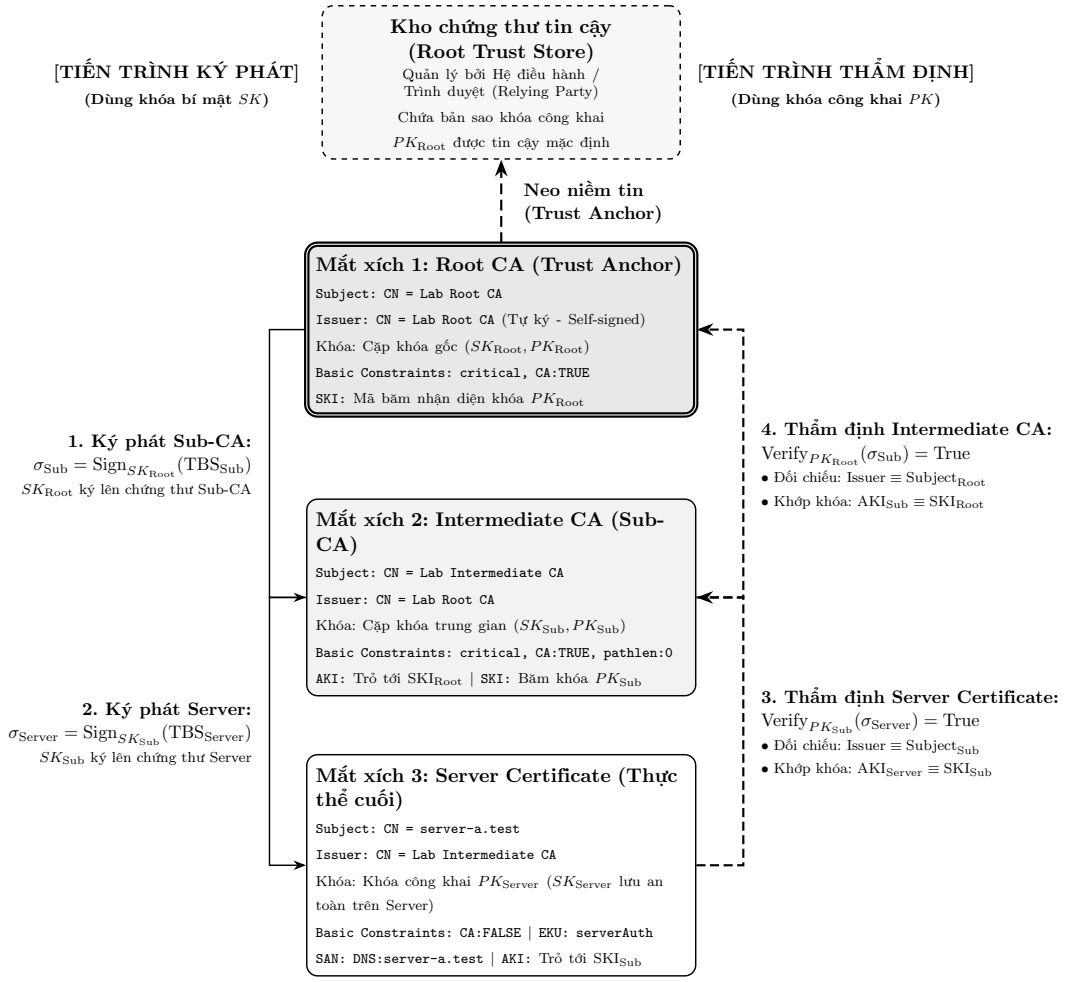
4.2 Xây dựng và xác minh đường dẫn

Một chứng thư máy chủ không tự mang đủ bằng chứng để được tin cậy. Relying party phải chỉ ra được một đường dẫn chứng thư (certification path) nối chứng thư đó tới một trust anchor mà chính nó đã cấu hình. Việc này gồm hai giai đoạn: xây dựng đường dẫn (path building) và xác minh đường dẫn (path validation, RFC 5280 [5], mục 6).

4.2.1 Chuỗi chứng thư trong lab

Lab dùng chuỗi ba mắt xích Root CA → Intermediate CA → chứng thư máy chủ, như minh họa ở Hình 4.2.

- **Root CA** (`Lab Root CA`): Chứng thư tự ký (Issuer ≡ Subject), `basicConstraints` critical với `CA:TRUE`. Khóa SK_{Root} dùng để ký chứng thư của Intermediate CA.
- **Intermediate CA** (`Lab Intermediate CA`): Được Root ký phát với chữ ký $\sigma_{\text{Sub}} = \text{Sign}_{SK_{\text{Root}}}(\text{TBS}_{\text{Sub}})$. Chứng thư này có cờ `CA:TRUE` và `pathlen:0`, nghĩa là chỉ được cấp chứng thư thực thể cuối, không được cấp thêm CA cấp dưới. Khóa SK_{Sub} dùng để ký chứng thư máy chủ.
- **Chứng thư máy chủ** (`server-a.test`): Được Intermediate CA ký phát với chữ ký $\sigma_{\text{Server}} = \text{Sign}_{SK_{\text{Sub}}}(\text{TBS}_{\text{Server}})$, thiết lập `CA:FALSE`, SAN `DNS:server-a.test` và EKU `serverAuth`.



Hình 4.2: Chuỗi chứng thư Root CA → Intermediate CA → server trong lab: quan hệ ký phát và quan hệ thẩm định giữa các mắt xích.

4.2.2 Quy trình xây dựng và xác minh

Xây dựng đường dẫn. Xuất phát từ chứng thư máy chủ, relying party tìm chứng thư của bên phát hành bằng cách khớp trường `Issuer` của chứng thư dưới với `Subject` của chứng thư trên, đồng thời khớp trường AKI với SKI (chỉ khớp tên là chưa đủ, vì một CA có thể có nhiều khóa cùng tên). Các chứng thư trung gian thường lấy từ chuỗi do máy chủ gửi kèm và chưa được tin cậy ở thời điểm này. Quá trình dừng khi gặp một chứng thư nằm trong kho trust anchor của client.

Trust anchor. Một Root CA tự ký chỉ trở thành trust anchor khi client được cấu hình để tin cậy nó (trong lab là tùy chọn `-CAfile`). Độ tin cậy của Root đến từ cấu hình đó, không đến từ chữ ký tự ký, vì bất kỳ ai cũng tạo được chứng thư tự ký cho chính mình.

Xác minh đường dẫn. Thuật toán của RFC 5280 quy định quy trình xử lý từng chứng thư trên đường dẫn từ trust anchor xuống chứng thư thực thể cuối qua 6 bước kiểm tra tuần tự:

1. **Xây dựng đường dẫn (Path Construction):** Truy vết các mắt xích từ chứng thư máy chủ ngược lên Trust Anchor dựa trên cặp định danh Issuer/Subject và AKI/SKI.

2. **Xác minh chữ ký số (Signature Verification):** Dùng khóa công khai của bên cấp phát để kiểm tra tính toàn vẹn toán học của chữ ký trên từng chứng thư trong chuỗi.
3. **Kiểm tra khung thời hạn hiệu lực (Validity Check):** Đối chiếu thời điểm xác minh với khoảng `[notBefore, notAfter]` của từng mắt xích.
4. **Kiểm tra ràng buộc CA và extension liên quan (Constraints Check):** Thẩm tra `basicConstraints` (cờ `cA:TRUE` cho CA, giới hạn `pathLen`) và các ràng buộc chính sách.
5. **Kiểm tra danh tính máy chủ và mục đích sử dụng (Identity & Purpose Matching):** So khớp tên miền truy cập với SAN và đối chiếu cờ EKU (`serverAuth`) theo yêu cầu ứng dụng.
6. **Kiểm tra trạng thái thu hồi (Revocation Status):** Tra cứu số sê-ri trong CRL hoặc truy vấn OCSP responder nếu chính sách kiểm tra thu hồi được kích hoạt.

Cần lưu ý quan trọng rằng công cụ `openssl verify` không mặc định thực thi toàn bộ các bước trên. Hành vi xác minh phụ thuộc trực tiếp vào các tùy chọn dòng lệnh: kiểm tra hostname bắt buộc phải khai báo tường minh qua `-verify_hostname`; kiểm tra mục đích TLS server cần chỉ định `-purpose sslserver`; và kiểm tra thu hồi đòi hỏi cờ `-crl_check`. Nếu thiếu các tùy chọn này, lệnh chỉ thực hiện xác minh chuỗi cơ bản. Mỗi mắt xích phải đạt các điều kiện ở Bảng 4.1. Chỉ cần một điều kiện không đạt là chứng thư bị từ chối theo chính sách xác minh được bật, dù các chữ ký vẫn đúng về mặt toán học. Đây là cơ sở của giả thuyết H_1 và được kiểm chứng bằng các ca TC02–TC08, TC10 ở Chương 6.

Điều kiện kiểm tra	**Áp dụng cho**	**Ca kiểm thử**
Chữ ký của chứng thư được tạo bằng khóa của bên phát hành	Mọi chứng thư, trừ trust anchor	TC05
Chuỗi nối được tới trust anchor đã cấu hình	Toàn đường dẫn	TC02, TC06, TC10
Thời điểm xác minh nằm trong [`notBefore`, `notAfter`]	Mọi chứng thư	TC03
Ràng buộc CA: `CA:TRUE` với mắt xích trung gian, `pathLenConstraint` không bị vượt	Root, Intermediate	Không có ca riêng
Mục đích sử dụng: Key Usage / EKU phù hợp (`serverAuth`)	Chứng thư máy chủ	TC08
Tên máy chủ khớp với SAN	Chứng thư máy chủ	TC04
Trạng thái thu hồi (chỉ khi được bật)	Mọi chứng thư	TC07 (xem Mục 4.3)

Bảng 4.1: Các điều kiện xác minh đường dẫn và ca kiểm thử tương ứng

Khi mọi điều kiện đều đạt, kết quả là PASS (TC01, TC09).

4.2.3 Quan sát từ lab

Hình 4.3 trình bày hai lần chạy `openssl verify` với cùng chứng thư `server-a.crt`.



Hình 4.3: Kết quả `openssl verify` với chuỗi đầy đủ (OK) và khi thiếu chứng thư Intermediate CA (lỗi 20, TC06).

Lần 1 (đủ chuỗi): Khi cung cấp Root qua `-CAfile` và Intermediate qua `-untrusted`, kết quả là `OK`, kèm `-purpose sslserver` và `-verify_hostname server-a.test` nên EKU và SAN cũng được kiểm. Chuỗi in ra gồm ba mức: depth 0 là server, depth 1 là Lab Intermediate CA, depth 2 là Lab Root CA. Nhãn `(untrusted)` ở depth 0 và 1 nghĩa là hai chứng thư này không nằm trong kho tin cậy; chỉ Root là trust anchor.

Lần 2 (thiếu Intermediate): Khi bỏ `-untrusted`, OpenSSL báo `error 20 at 0 depth lookup: unable to get local issuer certificate`. Chữ ký trên chứng thư máy chủ vẫn đúng, nhưng không tìm được chứng thư của bên phát hành nên không dựng được đường dẫn tới trust anchor. Lỗi gắn với depth 0 vì đó là chứng thư không tìm được issuer. Đây là ca TC06.

Cần lưu ý hai điểm. Thứ nhất, cả hai lệnh không bật kiểm tra thu hồi, nên `OK` chỉ cho biết các điều kiện trong Bảng 4.1 (trừ thu hồi) đã đạt; trạng thái thu hồi được xét riêng ở Mục 4.3. Thứ hai, kết quả của TC06 phụ thuộc vào client: OpenSSL không tự bổ sung chứng thư trung gian còn thiếu, trong khi một số client khác có cơ chế bù (qua AIA hoặc bộ nhớ đệm). Điều này phù hợp với giới hạn của lab đã nêu ở Mục 6.4.

4.3 Thu hồi và trạng thái chứng thư

Một chứng thư có chữ ký đúng và còn trong khoảng `[notBefore, notAfter]` vẫn có thể không còn đáng tin, ví dụ khi khóa bí mật bị lộ hoặc CA cấp sai (Mục 3.2, Bước 9). Relying party vì vậy cần một cách hỏi chứng thư đã bị thu hồi chưa. RFC 5280 [5] định nghĩa danh sách thu hồi chứng thư (CRL), còn RFC 6960 [6] định nghĩa giao thức trạng thái chứng thư trực tuyến (OCSP). Hai cơ chế trả lời cùng một câu hỏi nhưng khác nhau ở cách thông tin được phát hành và lấy về.

4.3.1 Danh sách thu hồi chứng thư (CRL)

CRL là danh sách có chữ ký do CA (hoặc CRL issuer được ủy quyền) phát hành định kỳ (RFC 5280 [5], mục 5). Mỗi CRL chứa số sê-ri các chứng thư bị thu hồi, thời điểm thu hồi và mã lý do tùy chọn (ví dụ `keyCompromise`), cùng hai trường `thisUpdate` và `nextUpdate` cho biết CRL được tạo khi nào và dự kiến được thay khi nào. Chứng thư chỉ nơi công bố CRL qua extension `CRL Distribution Points`. Khi xác minh, relying party tải CRL, kiểm tra chữ ký bằng khóa của bên phát hành, kiểm tra CRL còn hiệu lực rồi tra số sê-ri của chứng thư (RFC 5280 [5], mục 6.3).

Điểm mạnh là client có thể dùng bản CRL đã lưu đệm đến hết `nextUpdate`, nên không cần liên lạc với CA ở mỗi kết nối. Điểm yếu là độ trễ: thu hồi chỉ có hiệu lực với client khi CRL mới được phát hành và tải về. Kích thước CRL cũng tăng theo số chứng thư bị thu hồi (RFC 5280 có cơ chế delta CRL để giảm bớt).

4.3.2 Giao thức trạng thái chứng thư trực tuyến (OCSP)

Với OCSP, client gửi tới OCSP responder một truy vấn chứa định danh của chứng thư (băm tên và khóa của bên phát hành cùng số sê-ri). Địa chỉ responder nằm trong extension `Authority Information Access` (RFC 6960 [6]). Responder trả về phản hồi có chữ ký với một trong ba trạng thái `good`, `revoked` hoặc `unknown`, kèm khoảng thời gian phản hồi có hiệu lực. Phản hồi do CA hoặc một responder được CA ủy quyền ký, và truy vấn có thể kèm nonce để chống phát lại. Máy chủ cũng có thể đính kèm sẵn phản hồi OCSP trong bắt tay TLS (OCSP stapling) để client không phải tự truy vấn (xem Mục 5.2).

Điểm mạnh là thông tin theo từng chứng thư, nhỏ gọn và mới hơn CRL. Điểm yếu là cần responder trực tuyến (khả dụng), responder biết client đang kiểm tra chứng thư nào (riêng tư), và khi không liên lạc được responder thì client phải tự quyết định chấp nhận hay từ chối.

Trong Web PKI, BR từ phiên bản 2.0.1 (hiệu lực 15/03/2024) đã chuyển OCSP thành tùy chọn và đặt yêu cầu công bố CRL [9]. Phân tích sâu hơn ở Mục 5.2.

4.3.3 So sánh CRL và OCSP

Bảng 4.2 tổng hợp so sánh giữa hai cơ chế CRL và OCSP.

Tiêu chí	**CRL**	**OCSP**
Đơn vị thông tin	Danh sách số sê-ri bị thu hồi của một CA	Trạng thái của một chứng thư
Độ mới	Giới hạn bởi chu kỳ phát hành (`nextUpdate`)	Mới hơn, tùy cách responder cập nhật
Băng thông	Lớn khi danh sách dài	Nhỏ mỗi truy vấn nhưng nhiều truy vấn
Riêng tư	Không lộ chứng thư cụ thể đang kiểm tra	Responder biết chứng thư đang được kiểm tra
Khả dụng	Dùng được bản đã lưu đệm đến `nextUpdate`	Phụ thuộc responder trực tuyến (trừ khi có stapling)
Trong lab	Triển khai và kiểm thử (TC07)	Chỉ phân tích lý thuyết

Bảng 4.2: So sánh CRL và OCSP

4.3.4 Trạng thái `good` không đồng nghĩa với chứng thư hợp lệ

RFC 6960 nêu rõ: `good` chỉ cho biết tối thiểu là chứng thư chưa bị thu hồi, không nhất thiết có nghĩa là chứng thư từng được cấp hay thời điểm phản hồi nằm trong thời hạn của chứng thư (RFC 6960 [6], mục 2.2). OCSP chỉ trả lời một câu hỏi trong Bảng 4.1 (trạng thái thu hồi) và không thay thế các câu còn lại: chuỗi tới trust anchor, `[notBefore, notAfter]`, Basic Constraints, EKU và SAN. Một chứng thư hết hạn, sai tên máy chủ hoặc sai EKU vẫn có thể nhận `good`. Nguyên lý này áp dụng cả cho CRL: không thấy số sê-ri trong CRL chỉ có nghĩa là chưa bị liệt kê.

Sự cố DigiNotar minh họa rủi ro này. Theo Fox-IT [4], hành vi thông thường theo RFC 2560 (tiền thân của RFC 6960) là trả `good` cho số sê-ri không có bản ghi. Vì vậy các chứng thư giả không có trong hồ sơ vẫn có thể qua bước kiểm tra thu hồi. Ngày 1/9/2011, responder được chuyển sang danh sách trắng, trả `revoked` cho mọi số sê-ri không xác định.

Liên hệ lab. Lab chỉ kiểm tra CRL: Intermediate CA thu hồi chứng thư bằng `openssl ca -revoke`, phát hành CRL bằng `openssl ca -gencrl`, và client xác minh với CRL được chỉ định tường minh. TC07 kiểm tra rằng chứng thư đã bị liệt kê bị từ chối khi kiểm tra CRL được bật; kết quả cụ thể ở Mục 6.3. Lệnh `openssl verify` mặc định không kiểm tra thu hồi, nên với client không bật CRL, chứng thư bị thu hồi vẫn có thể qua các bước còn lại. Điều này khớp với giả thuyết H_2.

4.4 Liên hệ TLS

Các mục trước xét việc xác minh chứng thư một cách độc lập. Trong thực tế, chứng thư được trình bày trong bắt tay TLS 1.3 [3], và việc một chứng thư "được chấp nhận" là kết quả của nhiều kiểm tra do các bên khác nhau thực hiện. Mục này làm rõ vai trò của chứng thư và thông điệp `CertificateVerify` trong bắt tay, rồi phân định kiểm tra nào thuộc giao thức, thư viện, ứng dụng hay chính sách riêng của trình duyệt.

4.4.1 Chứng thư và `CertificateVerify` trong bắt tay TLS 1.3

Sau khi hai bên thỏa thuận khóa phiên (ClientHello và ServerHello mang `key_share`), máy chủ gửi ba thông điệp xác thực (RFC 8446 [3], mục 4.4):

- **`Certificate`:** Chuỗi chứng thư, chứng thư thực thể cuối đứng đầu, tiếp theo là các chứng thư trung gian. Chứng thư của trust anchor có thể được lược bỏ khi client đã có sẵn (RFC 8446 [3], mục 4.4.2). Đây là lý do thiếu Intermediate (TC06) khiến client không dựng được đường dẫn.
- **`CertificateVerify`:** Chữ ký của máy chủ, tạo bằng khóa bí mật tương ứng với khóa công khai trong chứng thư thực thể cuối, tính trên giá trị băm của toàn bộ các thông điệp bắt tay trước đó (RFC 8446 [3], mục 4.4.3).
- **`Finished`:** Mã xác thực (MAC) trên toàn bộ bắt tay, xác nhận hai bên cùng suy ra một bộ khóa và một bản ghi bắt tay (RFC 8446 [3], mục 4.4.4).

Hai chữ ký trong bắt tay có vai trò khác nhau và bổ sung cho nhau:

- Chữ ký của CA trên chứng thư trả lời câu hỏi "khóa này thuộc về tên này theo CA mà client tin cậy".
- `CertificateVerify` trả lời câu hỏi "bên đang kết nối thật sự nắm khóa bí mật tương ứng, trong chính phiên này", vì nội dung được ký bao gồm cả `key_share` của phiên.

Thiếu `CertificateVerify`, kẻ tấn công có thể trình lại chứng thư công khai của máy chủ mà không có khóa bí mật. Thiếu xác minh đường dẫn, kẻ tấn công trình chứng thư tự tạo kèm chữ ký đúng, đúng như kịch bản thay thế khóa của Eve ở Mục 1.1.3. Cần cả hai thì kết nối mới chống được kịch bản đó.

Hai chữ ký này cũng khác nhau về thuật toán. Chữ ký `CertificateVerify` phải dùng các thuật toán client chấp nhận trong `signature_algorithms`, và với RSA thì dùng RSA-PSS (RFC 8446 [3], mục 4.2.3). Chữ ký của CA trên chứng thư (ví dụ `sha256WithRSAEncryption` ở Hình 4.1) có thể dùng PKCS#1 v1.5.

Giới hạn quan trọng là `CertificateVerify` chỉ chứng minh sở hữu khóa, không chứng minh chứng thư được cấp đúng. Với DigiNotar, kẻ tấn công vừa có chứng thư giả `*.google.com` do CA bị chiếm ký, vừa nắm khóa bí mật tương ứng, nên mọi kiểm tra mật mã trong bắt tay đều đạt. Theo Fox-IT [4], sự cố lộ ra vì Chrome có kiểm tra bổ sung (certificate pinning) cho chứng thư của Google. Đây là cơ sở cho Mục 5.3.

4.4.2 Phân định các kiểm tra

RFC 8446 chỉ quy định phần xác thực nằm trong giao thức. Việc xác minh chứng thư chi tiết được dẫn tới RFC 5280 (RFC 8446 [3], mục 4.4.2.4; [5]). Việc đối chiếu tên máy chủ do RFC 9525 [11] quy định, và RFC này chỉ xét tên trong chứng thư máy chủ cuối, không xét việc xác minh chuỗi. Bảng 4.3 phân định ai chịu trách nhiệm kiểm tra gì.

Hai hệ quả cần nhấn mạnh:

- Nhiều thư viện không tự bật kiểm tra tên máy chủ hay kiểm tra thu hồi; ứng dụng phải yêu cầu (trong lab là `-verify_hostname` và kiểm tra CRL được bật tường minh). Vì vậy một kết nối TLS "thành công" chưa chắc đã qua đủ các kiểm tra ở Bảng 4.1.
- Cùng một chứng thư có thể được chấp nhận ở client này và bị từ chối ở client khác tùy cấu hình và chính sách. Các ca kiểm thử trong lab phản ánh tầng "thư viện OpenSSL kèm cấu hình" chứ không phải chính sách của trình duyệt (xem Mục 6.4).

Phạm vi của công cụ trong lab. Lệnh `openssl verify` đọc các chứng thư được cung cấp và chạy thuật toán xác minh đường dẫn theo hồ sơ PKIX (RFC 5280 [5]) tại một thời điểm xác định. Lệnh này không thiết lập bắt tay TLS, không trao đổi `key_share`, không tính giá trị băm của bản ghi bắt tay và không kiểm tra việc nắm giữ khóa bí mật thông qua `CertificateVerify` (RFC 8446 [3]). Vì vậy kết quả TC01–TC10 phản ánh tầng xác minh chứng thư, không phản ánh toàn bộ một kết nối TLS. Việc kiểm tra bằng `openssl s_server` và `openssl s_client` là hướng mở rộng.

Kiểm tra	**Bên thực hiện**	**Nguồn quy định**	**Trong lab**
Cấu trúc thông điệp `Certificate`, kiểu chứng thư, khóa tương thích	Giao thức TLS	RFC 8446 [3]	Không kiểm tra
`CertificateVerify` (sở hữu khóa) và `Finished`	Giao thức TLS	RFC 8446 [3]	Không kiểm tra
Dựng và xác minh đường dẫn, thời hạn, Basic Constraints, Key Usage/EKU	Thư viện TLS, với trust anchor, thời điểm và mục đích sử dụng do ứng dụng cấu hình	RFC 5280 [5]	TC01–TC03, TC05, TC06, TC08, TC10
Trạng thái thu hồi	Ứng dụng quyết định có kiểm tra không, dùng CRL hay OCSP, và hành vi khi lỗi; TLS chỉ cho phép đính kèm phản hồi OCSP (stapling)	RFC 5280 [5], RFC 6960 [6]	TC07 (chỉ CRL)
Khớp tên máy chủ với SAN	Ứng dụng, hoặc thư viện khi ứng dụng yêu cầu	RFC 9525 [11]	TC04
Chính sách riêng của trình duyệt và Root Store: danh mục trust anchor, yêu cầu CT, pinning, giới hạn thời hạn chứng thư	Trình duyệt hoặc nhà cung cấp Root Store	Ngoài RFC 5280 và 8446; một phần theo BR [9]	Không có

Bảng 4.3: Phân định các kiểm tra trong kết nối TLS 1.3

Chương 5

Phân tích bảo mật, mô hình tấn công và so sánh

5.1 Tài sản, đối thủ và rủi ro

5.1.1 Tài sản cần bảo vệ

An toàn của PKI phụ thuộc vào một số ít tài sản then chốt. Bảng 5.1 liệt kê các tài sản đó, yêu cầu bảo vệ và hậu quả khi bị xâm phạm.

Tài sản	**Yêu cầu bảo vệ**	**Hậu quả khi bị xâm phạm**	**Trong lab**
Khóa bí mật Root CA	Bí mật	Ký được chứng thư CA và chứng thư máy chủ bất kỳ; ảnh hưởng mọi client tin Root đó	Tệp khóa trên ổ đĩa (Bảng 3.4)
Khóa bí mật Intermediate CA	Bí mật	Cấp được chứng thư máy chủ cho tên bất kỳ; có thể cô lập bằng cách thu hồi chứng thư của CA con	Tệp khóa trên ổ đĩa
Khóa bí mật máy chủ	Bí mật	Mạo danh máy chủ cho đến khi chứng thư hết hạn hoặc bị thu hồi	Khóa của `server-a`
Trust store của client	Toàn vẹn	Thêm trust anchor lạ thì mọi chứng thư do nó ký đều được tin cậy	Tệp `root.crt` qua `-CAfile`
Quy trình và cấu hình xác minh	Toàn vẹn, đầy đủ	Bỏ kiểm tra tên, EKU hoặc thu hồi thì chứng thư không phù hợp vẫn được chấp nhận	Các cờ `-purpose`, `-verify_hostname`, kiểm tra CRL
Thông tin trạng thái thu hồi (CRL/OCSP)	Toàn vẹn, kịp thời, sẵn sàng	Chứng thư đã bị thu hồi vẫn được chấp nhận	Tệp CRL do Intermediate CA phát hành

Bảng 5.1: Tài sản cần bảo vệ trong mô hình PKI phân cấp

5.1.2 Mô hình đối thủ và giả định

Mô hình đe dọa trong PKI được phân tầng thành hai kịch bản đối thủ với năng lực và phạm vi ảnh hưởng khác nhau:

- **Đối thủ trên đường truyền (Network-level Attacker – Eve):** Đây là đối thủ cơ sở ở Mục 1.1.3, có khả năng quan sát, đánh chặn và can thiệp luồng dữ liệu mạng giữa client và server nhằm tráo khóa công khai hoặc mạo danh máy chủ. Giả định các thuật toán mật mã là an toàn (Eve không thể bẻ khóa hay phá hàm băm). Quy trình thẩm định chuỗi và đối chiếu ngữ cảnh (RFC 5280) được thiết kế để triệt tiêu hoàn toàn kịch bản này.
- **Đối thủ xâm nhập CA hoặc can thiệp Trust Store (System-level Attacker):** Lớp đối thủ nguy hiểm hơn, bao gồm: kẻ đánh cắp khóa bí mật máy chủ; kẻ can thiệp Trust Store cục bộ; hoặc nguy hiểm nhất là kẻ chiếm quyền kiểm soát CA (sự cố DigiNotar, Mục 5.1.4). Kẻ tấn công ký phát được chứng thư giả mạo hợp lệ về toán học và dẫn chuỗi về Trust Anchor có sẵn. Xác minh cục bộ của client hoàn toàn bất lực trước đối thủ cấp hệ thống này.

5.1.3 Các mối đe dọa và rủi ro

Bảng 5.2 phân loại các mối đe dọa, tài sản liên quan, cơ chế kiểm soát và giới hạn thực tế trong PKI.

Hai nhận xét rút ra từ Bảng 5.2:

- Thứ nhất, ba hàng đầu (lộ khóa máy chủ, lộ khóa CA, CA bị xâm nhập) vẫn cho ra chuỗi chứng thư và chữ ký hợp lệ, nên xác minh đường dẫn không phát hiện được chúng; chỉ có thu hồi hoặc giám sát từ bên ngoài mới giảm thiểu được.
- Thứ hai, các hàng còn lại phụ thuộc vào việc client có bật kiểm tra hay không, nên lab quan sát được trực tiếp hành vi này.

5.1.4 Phân tích trường hợp DigiNotar

DigiNotar là CA của Hà Lan có root nằm trong danh sách tin cậy của nhiều trình duyệt và hệ điều hành, đồng thời quản lý các CA phục vụ chứng thư SSL, chứng thư chữ ký điện tử có giá trị pháp lý và chứng thư chính phủ [4].

Diễn biến. Theo Fox-IT [4]:

- Ngày 17/6/2011, kẻ tấn công vào qua các máy chủ web ở vùng DMZ ngoài. Điều tra ban đầu cho rằng chúng khai thác phần mềm DotNetNuke lỗi thời.
- Ngày 1/7/2011, chúng vào được vùng mạng chứa các máy chủ CA.
- Ngày 10/7/2011, chứng thư giả đầu tiên được cấp thành công.
- Cả tám máy chủ quản lý CA đều bị chiếm quyền, và ít nhất 531 chứng thư giả đã được phát hành (danh sách chưa đầy đủ), trong đó có chứng thư wildcard cho `*.google.com`.
- DigiNotar tự phát hiện sự bất thường ngày 19/7/2011 qua một kiểm tra định kỳ và thu hồi các số sê-ri đã biết. Chứng thư wildcard của Google có số sê-ri không nằm trong hồ sơ của CA và chưa được thu hồi.

Mối đe dọa	Tài sản liên quan	Cơ chế kiểm soát	Giới hạn	Trong lab
Lộ khóa bí mật máy chủ	Khóa máy chủ	Thu hồi chứng thư (CRL/OCSP, lý do `keyCompromise`); chứng thư thời hạn ngắn	Thu hồi có độ trễ và chỉ có tác dụng nếu client kiểm tra (H_2)	TC07
Lộ khóa CA	Khóa Root / Intermediate	Root để offline; thu hồi chứng thư CA con; loại CA khỏi trust store	Thu hồi Root đòi hỏi cập nhật trust store của mọi client	Chỉ phân tích lý thuyết
CA cấp sai hoặc bị xâm nhập (rogue certificate)	Khóa CA, quy trình cấp phát	Giám sát (Certificate Transparency [10]), certificate pinning, loại CA khỏi trust store	Chữ ký và chuỗi vẫn hợp lệ nên xác minh đường dẫn không phát hiện được	Chỉ phân tích lý thuyết
MITM bằng chứng thư tự tạo hoặc tự ký	Trust store	Xác minh đường dẫn tới trust anchor đã cấu hình	Vô hiệu nếu trust store bị can thiệp	TC02, TC05, TC10
Chứng thư hợp lệ nhưng dùng sai tên hoặc sai mục đích	Quy trình xác minh	Kiểm tra SAN, Key Usage/EKU	Phụ thuộc client có bật kiểm tra	TC04, TC08
Chứng thư hết hạn	Quy trình xác minh	Kiểm tra `[notBefore, notAfter]`	Phụ thuộc đồng hồ và chính sách của client	TC03
Kiểm tra thu hồi không đầy đủ	Thông tin thu hồi	Bật CRL/OCSP; stapling; chứng thư thời hạn ngắn	Client không kiểm tra, CRL cũ, hoặc responder trả lời sai	TC07 (chỉ CRL)

Bảng 5.2: Các mối đe dọa và cơ chế kiểm soát trong PKI

- Ngày 28/8/2011, chứng thư giả đó mới bị lộ khi Chrome chặn nó nhờ certificate pinning. Nó đã được dùng trong một cuộc MITM nhằm vào khoảng 298.140 địa chỉ IP (ước tính thô số người dùng), xấp xỉ 95% ở Iran.
- Ngày 3/9/2011, chính phủ Hà Lan rút lòng tin với DigiNotar và hầu hết nhà sản xuất trình duyệt làm theo; công ty phá sản ngày 20/9/2011.

Vì sao các cơ chế xác thực không phát hiện được. Các chứng thư giả do chính CA công cộng ký, bằng khóa nằm trong HSM đang được kích hoạt, và nối chuỗi tới root đã nằm sẵn trong trust store. Vì vậy mọi bước ở Bảng 4.1 và mọi kiểm tra trong bắt tay TLS (Mục 4.4) đều đạt. Sự cố là minh chứng cho giả thuyết H_1 ở quy mô thực tế: chữ ký đúng chưa đủ để chứng thư đáng tin.

Điểm yếu của cơ chế thu hồi. Chứng thư giả không có trong cơ sở dữ liệu của CA nên không thể thu hồi theo cách thông thường: DigiNotar phải tạo một chứng thư khác cùng số sê-ri rồi thu hồi nó. Đến ngày 01/09/2011, theo khuyến nghị của Fox-IT, responder OCSP của DigiNotar mới được chuyển sang cơ chế danh sách trắng, trả về `revoked` cho mọi số sê-ri không tồn tại trong hồ sơ phát hành hợp pháp [4]. Nhật ký OCSP sau đó trở thành nguồn để ước lượng số người bị ảnh hưởng. Điều này cho thấy thu hồi chỉ xử lý được những chứng thư mà CA biết.

Điểm yếu vận hành. Nhật ký của các máy chủ CA nằm ngay trên các máy bị chiếm quyền và đã bị can thiệp, nên sự vắng mặt của bản ghi đáng ngờ không chứng minh được là không có cấp phát trái phép. Các vùng mạng không được mô tả và thực thi chặt,

firewall có nhiều ngoại lệ [4]. HSM, chính sách và kiểm toán là điều kiện cần nhưng không đủ (xem thêm Mục 3.3.4).

Bài học đối chiếu với Bảng 5.1 và 5.2:

- Một CA công cộng ký được cho bất kỳ tên miền nào, nên khóa CA là tài sản có phạm vi ảnh hưởng toàn cầu.
- Việc phát hiện đến từ bên ngoài (pinning của Chrome), không đến từ xác minh đường dẫn. Đây là động lực cho cơ chế giám sát như Certificate Transparency (RFC 9162 [10]), vốn phát hiện cấp phát sai chứ không tự ngăn chặn (Mục 7.1).
- Thu hồi không giải quyết được trường hợp CA không biết mình đã cấp chứng thư nào.

Liên hệ với mô hình lab của đề tài. Kịch bản DigiNotar minh họa rõ nét giới hạn căn bản của mô hình tin cậy khi chính CA được tin cậy bị xâm nhập; các ca kiểm thử trong lab của đề tài (Chương 6) chủ yếu kiểm tra những điều kiện xác minh ngữ cảnh cục bộ theo RFC 5280, không mô phỏng đầy đủ tình huống CA công cộng bị thỏa hiệp toàn diện.

5.2 So sánh các cơ chế tin cậy và thu hồi

Mục 5.1 cho thấy rủi ro của PKI đến từ hai phía: sự tin cậy tập trung vào CA và độ trễ của thu hồi. Mục này so sánh (i) ba mô hình tin cậy theo giả định mà chúng đặt ra, và (ii) ba cách giới hạn thời gian một chứng thư xấu còn được chấp nhận, theo độ mới, chi phí và khả dụng. Các so sánh mang tính định tính, dựa trên chuẩn và kết quả lab; mục đích không phải chọn ra một mô hình vượt trội trong mọi môi trường.

5.2.1 Ba mô hình tin cậy

Ba mô hình tin cậy tiêu biểu trong xác thực khóa công khai bao gồm:

- **PKI dựa trên CA:** Một tập CA được client tin cậy (trust store) bảo chứng liên kết giữa tên và khóa.
- **Web of Trust (mạng lưới tin cậy):** Không có CA trung tâm; người dùng tự ký xác nhận khóa của nhau và tự quyết định mức tin cậy.
- **TOFU (Trust On First Use):** Client chấp nhận khóa ở lần kết nối đầu tiên rồi ghi nhớ; các lần sau, khóa thay đổi sẽ gây cảnh báo.

Bảng 5.3 đối chiếu ba mô hình theo các giả định tin cậy và đặc tính kỹ thuật cốt lõi.

Bảng 5.3 cho thấy PKI không loại bỏ nhu cầu về một điểm tin cậy ban đầu xác thực, mà chỉ thu hẹp nó: từ khóa của từng bên (kịch bản Eve ở Mục 1.1.3) xuống một số ít trust anchor. Lab thuộc nhóm PKI dựa trên CA, nhưng `root.crt` được cấu hình thủ công qua `-CAfile`, tức trust anchor được phân phối ngoài băng; nếu bị thay thế, mọi chứng thư do Root giả ký đều được chấp nhận (Bảng 5.1). Điều này giống TOFU ở khâu thiết lập ban đầu.

Không mô hình nào vượt trội ở mọi môi trường. Với Web công cộng, nơi các bên chưa từng quen biết nhau, PKI dựa trên CA là lựa chọn khả thi, nhưng tin cậy tập trung buộc

Tiêu chí	PKI dựa trên CA	Web of Trust	TOFU
Giả định tin cậy	CA trong trust store hoạt động đúng và giữ khóa an toàn; trust store của client toàn vẹn	Người dùng tin những người đã ký xác nhận khóa, và tin bắc cầu qua họ	Kẻ tấn công không có mặt ở lần kết nối đầu tiên
Ai quyết định tin	CA và nhà quản lý Root Store; người dùng cuối thường không phải quyết định	Từng người dùng	Client ở lần đầu, sau đó khóa được ghi nhớ
Khả năng mở rộng	Tốt (quy mô toàn cầu)	Kém khi vượt cộng đồng nhỏ	Tốt về kỹ thuật; mỗi cặp client–server tự thiết lập
Điểm yếu chính	Một CA bị xâm nhập ký được cho mọi tên (DigiNotar, Mục 5.1.4)	Khó dùng; đánh giá tin cậy bắc cầu dễ sai	Cửa sổ MITM ở lần đầu; đổi khóa hợp lệ dễ gây cảnh báo giả
Thu hồi, thay khóa	CRL, OCSP, loại CA khỏi trust store	Chủ khóa công bố chứng thư thu hồi, phụ thuộc phân phối	Người dùng tự xóa hoặc thay khóa đã ghi nhớ
Ví dụ điển hình	Web PKI, PKI nội bộ	PGP	SSH (`known_hosts`)

Bảng 5.3: So sánh ba mô hình tin cậy theo giả định tin cậy

phải bổ sung giám sát như Certificate Transparency (RFC 9162 [10], Mục 7.1). Với nhóm nhỏ hoặc quản trị hệ thống, TOFU hoặc PKI nội bộ có chi phí vận hành thấp. Với cộng đồng cá nhân có quan hệ trực tiếp, Web of Trust tránh được CA trung tâm. Trong thực tế, các mô hình thường được kết hợp.

5.2.2 Thu hồi và rút ngắn thời hạn

Ba cách giới hạn khoảng thời gian một chứng thư xấu còn được chấp nhận là CRL, OCSP và chứng thư thời hạn ngắn. Chi tiết của CRL và OCSP nằm ở Mục 4.3. Bảng 5.4 tổng hợp so sánh giữa ba phương thức này.

Xu hướng của Web PKI nghiêng về rút ngắn thời hạn: Baseline Requirements [9] đã ấn định thời hạn tối đa 200 ngày từ 15/03/2026, 100 ngày từ 15/03/2027 và 47 ngày từ 15/03/2029, đồng thời định nghĩa riêng loại chứng thư thời hạn rất ngắn (tối đa 7 ngày với chứng thư cấp từ 15/03/2026). Cách này không cần ai kiểm tra thu hồi, nhưng vẫn còn cửa sổ rủi ro bằng thời hạn còn lại, nên không thay thế hoàn toàn thu hồi.

Cả ba cơ chế đều chỉ xử lý được những chứng thư mà CA biết hoặc những chứng thư hết hạn. Trường hợp DigiNotar (Mục 5.1.4) cho thấy chúng không giúp được khi CA bị chiếm quyền và cấp chứng thư ngoài hồ sơ, nên cần giám sát từ bên ngoài như Certificate Transparency (RFC 9162 [10], Mục 7.1). Cơ chế phù hợp phụ thuộc vào môi trường: PKI nội bộ nhỏ có thể dùng CRL đơn giản; hệ thống công cộng quy mô lớn ưu tiên thời hạn ngắn kèm tự động hóa.

Cơ chế	Độ mới	Chi phí	Khả dụng	Giới hạn chính
CRL	Tối đa bằng chu kỳ phát hành (`nextUpdate`)	Tải cả danh sách; lớn khi nhiều chứng thư bị thu hồi	Dùng được bản lưu đệm đến `nextUpdate`, không cần liên lạc mỗi kết nối	Độ trễ thu hồi
OCSP	Mới hơn, theo thời hạn hiệu lực của phản hồi	Một truy vấn cho mỗi chứng thư; responder phải ký và phục vụ	Phụ thuộc responder trực tuyến (stapling giảm phụ thuộc)	Lộ chứng thư đang kiểm tra cho responder; hành vi khi lỗi do client quyết định
Chứng thư thời hạn ngắn	Giới hạn bởi thời hạn của chứng thư	Cấp phát tần suất cao, cần tự động hóa (ACME [12])	Phụ thuộc CA luôn sẵn sàng khi gia hạn	Không thu hồi tức thời trong phần thời hạn còn lại

Bảng 5.4: So sánh CRL, OCSP và chứng thư thời hạn ngắn

Lab chỉ kiểm thử CRL (TC07), nên phần so sánh OCSP và chứng thư thời hạn ngắn là phân tích lý thuyết. Giả thuyết H_2 (độ trễ và sự phụ thuộc của thu hồi) được kiểm chứng qua TC07. Giả thuyết H_3 về chi phí vẫn mang tính định tính trong Bảng 5.4; nếu muốn kiểm chứng thực nghiệm, một phép đo nhỏ (kích thước CRL và thời gian xác minh theo số chứng thư bị thu hồi) là đủ, còn nếu không làm thì ghi rõ H_3 chưa được kiểm chứng.

5.3 Giới hạn của chữ ký hợp lệ

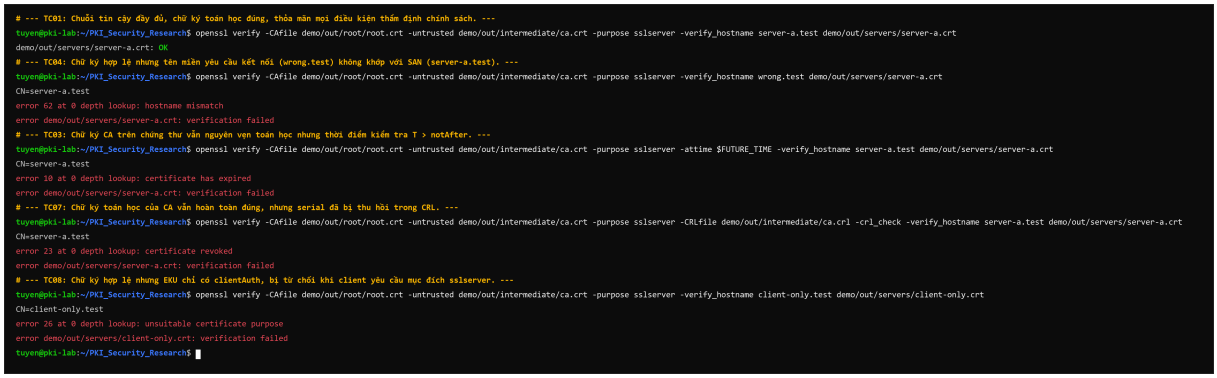
Từ phân tích lý thuyết ở các mục trước và bằng chứng thực nghiệm tại Chương 6, có thể khẳng định: **chữ ký số hợp lệ chỉ là điều kiện cần (necessary condition), hoàn toàn không phải là điều kiện đủ (sufficient condition) để chứng thư được client tin cậy** (chứng minh cho giả thuyết H_1). Về mặt toán học, chữ ký số của CA chỉ bảo đảm tính toàn vẹn của nội dung chứng thư và tính xác thực nguồn gốc từ thực thể nắm giữ khóa bí mật. Tuy nhiên, tính đúng đắn mật mã này không mang ngữ nghĩa ngữ cảnh (*semantic context*) và không phản ánh trạng thái vận hành theo thời gian thực.

Kết quả kiểm thử thực nghiệm tại Mục 6.3 cung cấp bằng chứng thực tế rõ ràng cho nhận định trên. Trong khi ca kiểm thử TC05 chứng minh chữ ký hợp lệ là điều kiện bắt buộc (chữ ký bị sửa đổi bit lập tức bị OpenSSL từ chối với `error 7: certificate signature failure`), thì ca kiểm thử chuẩn TC01 đóng vai trò làm mốc đối chứng (baseline) khi thỏa mãn trọn vẹn cả tính đúng đắn toán học lẫn các điều kiện chính sách. Ngược lại, một loạt ca kiểm thử khác (TC02, TC03, TC04, TC06, TC07, TC08, TC10) chỉ ra rằng dù chữ ký toán học hoàn toàn nguyên vẹn, chứng thư vẫn bị client bác bỏ ngay lập tức nếu vi phạm một trong các ràng buộc ngữ cảnh:

1. **Không dẫn tới Trust Anchor được cấu hình:** Chứng thư tự ký không được tin cậy (TC02 – `error 18: self-signed certificate`) hoặc chuỗi chứng thư hợp lệ nhưng thuộc về một CA nằm ngoài Trust Store của client (TC10 – `error 20: unable to get local issuer certificate`).

2. **Đứt gãy đường dẫn chứng thư:** Thiếu chứng thư Intermediate CA trong chuỗi truyền nhận khiến client không thể dựng tiếp đường dẫn lên Trust Anchor (TC06 – `error 20: unable to get local issuer certificate`).
3. **Thời điểm xác minh nằm ngoài khung hiệu lực:** Thời gian kiểm tra nằm ngoài khoảng `[notBefore, notAfter]` (TC03 – `error 10: certificate has expired`).
4. **Tên máy chủ truy cập không trùng khớp với SAN:** Tên miền yêu cầu kết nối không nằm trong danh sách Subject Alternative Name (TC04 – `error 62: hostname mismatch`).
5. **Mục đích sử dụng thực tế không được cấp phép trong EKU:** Chứng thư chỉ cấp cờ `clientAuth` bị từ chối khi hoạt động với vai trò TLS server (TC08 – `error 26: unsuitable certificate purpose`).
6. **Trạng thái chứng thư đã bị thu hồi trong CRL:** Khóa hoặc chứng thư bị thỏa hiệp và đã đưa vào danh sách thu hồi (TC07 – `error 23: certificate revoked`).

Bên cạnh đó, quyết định xác minh mang tính tương đối và phụ thuộc trực tiếp vào chính sách cũng như các cờ kiểm tra do client kích hoạt, đúng như dự đoán của giả thuyết H_2. Điển hình ở trường hợp thu hồi (đối chiếu giữa TC01 và TC07): chữ ký của CA trên chứng thư là một giá trị mật mã bất biến, nhưng trạng thái tin cậy của nó đã bị hủy bỏ; nếu client không chủ động bật cờ kiểm tra danh sách thu hồi (`-crl_check`), chứng thư bị thu hồi vẫn vượt qua toàn bộ quy trình thẩm định để được chấp nhận. Tương tự, nếu client bỏ qua cờ kiểm tra tên máy chủ hoặc sử dụng một trust store bị cài cắm CA độc hại, tính hợp lệ toán học của chữ ký hoàn toàn không còn mang ý nghĩa bảo vệ.



Hình 5.1: Minh chứng thực nghiệm: Cùng một chứng thư có chữ ký hợp lệ nhưng bị từ chối ở các tầng kiểm tra ngữ cảnh khác nhau (TC01, TC04, TC03, TC07, TC08).

Hình 5.1 đối chiếu trực quan 5 ca kiểm thử thực tế trên cùng một hệ thống lab: từ mốc đối chứng chuẩn TC01 (thẩm định thành công toàn diện) cho đến các trường hợp bị client từ chối do sai tên miền (TC04), hết hạn (TC03), bị thu hồi (TC07) và sai mục đích EKU (TC08). Ở mọi ca thất bại, chữ ký số của CA trên chứng thư đều hoàn toàn nguyên vẹn về mặt toán học, nhưng quá trình xác minh của OpenSSL trả về kết quả thất bại và thông báo lỗi tương ứng với điều kiện bị vi phạm trong cấu hình thử nghiệm. Mã lỗi quan sát được phụ thuộc vào lệnh, tùy chọn xác minh và trạng thái của chuỗi chứng thư.

Những giới hạn trên dẫn đến hai bài học kiến trúc then chốt trong thiết kế và vận hành PKI:

- **Thứ nhất, an toàn của một phiên giao dịch phụ thuộc vào toàn bộ quy trình thẩm định chuỗi và ngữ cảnh tại client (RFC 5280 [5], Mục 4.2), chứ không chỉ dựa vào thuật toán ký số.** Chữ ký số hợp lệ cho thấy chữ ký trên chứng thư phù hợp với nội dung được ký và khóa công khai của bên phát hành dùng để xác minh. Tuy nhiên, điều này không tự chứng minh rằng quy trình cấp phát đã xác minh danh tính chính xác, rằng bên phát hành được client tin cậy, hoặc rằng chứng thư vẫn hợp lệ và được sử dụng đúng mục đích tại thời điểm kết nối.
- **Thứ hai, việc xác minh cục bộ của client hoàn toàn bất lực trước kịch bản CA công cộng bị thỏa hiệp và phát hành chứng thư sai phạm có chủ đích.** Trong kịch bản DigiNotar (Mục 5.1.4), chứng thư giả mạo được cấp dưới danh nghĩa một CA mà các client liên quan vẫn tin cậy. Khi chuỗi chứng thư và các điều kiện xác minh cục bộ đều đáp ứng chính sách đang áp dụng, client có thể chấp nhận chứng thư dù việc cấp phát thực tế là sai phạm. Trường hợp này cho thấy xác minh chữ ký và chuỗi tin cậy không thể tự phát hiện mọi hành vi cấp chứng thư gian lận của một CA đã bị thỏa hiệp. Để giảm thiểu rủi ro này, Web PKI hiện đại bổ sung các cơ chế mở rộng: Certificate Transparency (RFC 9162 [10]) cung cấp nhật ký công khai để hỗ trợ giám sát và phát hiện cấp phát bất thường từ bên ngoài; còn DNS CAA (RFC 8659 [13]) cho phép chủ sở hữu tên miền công bố các CA được phép cấp phát theo chính sách nhằm hạn chế cấp sai ngay từ nguồn. Chi tiết ứng dụng của các cơ chế này sẽ được phân tích ở Chương 7.

Sự kết hợp giữa phân tích lý thuyết ở chương này và các kịch bản kiểm thử được thiết kế chi tiết tại Chương 6 sẽ là tiền đề thực tiễn để đề xuất các giải pháp tăng cường an ninh toàn diện tại Chương 7.

Chương 6

Thiết kế và đánh giá thực nghiệm

6.1 Giả thuyết và môi trường

6.1.1 Các giả thuyết nghiên cứu

Để giải quyết các câu hỏi nghiên cứu (RQ) đặt ra tại Mục 1.2, thực nghiệm được thiết kế nhằm kiểm chứng ba giả thuyết kỹ thuật cốt lõi:

- **Giả thuyết H_1 (Điều kiện cần của chữ ký số):** Chữ ký số hợp lệ chỉ là điều kiện cần chứ chưa đủ để một chứng thư số được client tin cậy. Chứng thư chỉ được chấp nhận khi thỏa mãn đồng thời toàn bộ các ràng buộc ngữ cảnh: chuỗi tin cậy tới Trust Anchor, thời hạn hiệu lực, định danh tên máy chủ, mục đích sử dụng và trạng thái thu hồi.
- **Giả thuyết H_2 (Tính động của quyết định xác minh):** Việc thay đổi các tham số ngữ cảnh (thời điểm kiểm tra, tên máy chủ, danh mục Trust Anchor) hoặc trạng thái thu hồi sẽ làm thay đổi trực tiếp quyết định thẩm định của client từ chấp thuận (`PASS`) sang từ chối (`FAIL`).
- **Giả thuyết H_3 (Giới hạn và chi phí vận hành của cơ chế xác minh):** Các cơ chế thẩm định trạng thái chứng thư có sự đánh đổi rõ rệt về chi phí và giới hạn vận hành; trong đó, cơ chế kiểm tra thu hồi qua danh sách CRL đòi hỏi chi phí lưu trữ, băng thông phân phối định kỳ và có độ trễ cập nhật nhất định giữa các lần phát hành.

6.1.2 Môi trường thực nghiệm

Toàn bộ quy trình sinh khóa, cấp phát chứng thư, thu hồi và thực thi bộ kiểm thử tự động được triển khai trên môi trường máy trạm với các thông số trích xuất trực tiếp từ hệ thống:

- **Hệ điều hành & Nhân Kernel:** Fedora Linux 43 (Container Image), chạy trên nền tảng WSL2 với nhân `Linux 6.6.87.2-microsoft-standard-WSL2` kiến trúc `x86_64`.

- **Công cụ mật mã:** OpenSSL phiên bản `3.5.9` (phát hành ngày 29/09/2026, biên dịch ngày 30/09/2026 UTC), sử dụng thư viện OpenSSL 3.5.9 và cấu hình crypto-policy hệ thống tiêu chuẩn (`OPENSSLDIR: "/etc/pki/tls"`).
- **Thiết bị phần cứng:** Bộ vi xử lý Intel(R) Core(TM) i7-11800H @ 2.30GHz (thế hệ thứ 11, 16 vCPU); dung lượng bộ nhớ RAM ảo hóa cấp phát cho WSL2 là 3.7 GiB (khả dụng 3.1 GiB).
- **Thời điểm thực thi kiểm thử:** 01:58:15 (UTC+7), Thứ Tư, ngày 28 tháng 10 năm 2026.

Thông số môi trường thực tế được tự động kiểm tra và ghi lại qua kịch bản kiểm tra môi trường, thể hiện tổng hợp tại Hình 6.1.

```
# ========================================================================== #
#          THÔNG SỐ MÔI TRƯỜNG THỰC NGHIỆM LAB PKI (MỤC 6.1)                 #
# ========================================================================== #
tuyen@pki-lab:~/PKI_Security_Research$ bash demo/scripts/check_env.sh
=== HE DIEU HANH VA NHAN KERNEL ===
Linux 6.6.87.2-microsoft-standard-WSL2 x86_64
Fedora Linux 43 (Container Image)
=== THIET BI PHAN CUNG ===
CPU: 11th Gen Intel(R) Core(TM) i7-11800H @ 2.30GHz
RAM WSL2: 3.7Gi (Kha dung: 3.1Gi)
=== PHIEN BAN OPENSSL ===
OpenSSL 3.5.9 29 Sep 2026 (Library: OpenSSL 3.5.9 29 Sep 2026)
OPENSSLDIR: "/etc/pki/tls"
=== THOI DIEM CHAY THUC NGHIEM ===
Wednesday, 28/10/2026 01:58:15 +07
tuyen@pki-lab:~/PKI_Security_Research$
```

Hình 6.1: Thông số môi trường hệ điều hành, phần cứng và phiên bản OpenSSL thực tế của bài lab.

6.2 Mô hình và quy trình

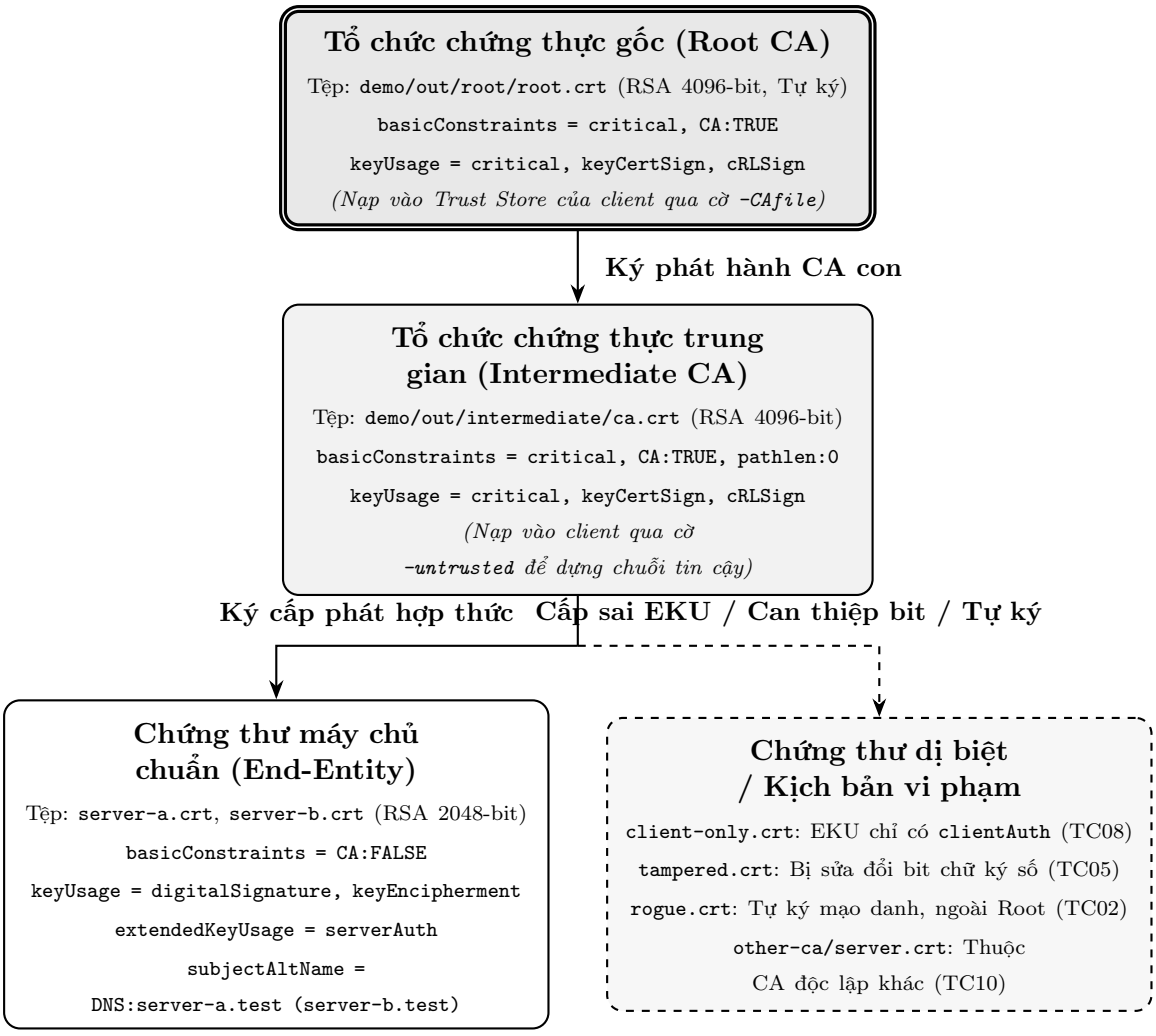
6.2.1 Mô hình phân cấp chứng thư (PKI Hierarchy)

Hệ thống phòng lab thiết lập mô hình PKI phân cấp 2 tầng theo chuẩn RFC 5280 [5] nhằm phản ánh đúng cấu trúc thực tế của Web PKI, được minh họa tại Hình 6.2.

6.2.2 Cấu hình X.509 Extensions và Chính sách xác minh

Để cô lập từng điều kiện kiểm thử, các chứng thư trong bài lab được cấu hình phần mở rộng (*extensions*) theo mục đích cụ thể:

- **Root CA (`root.crt`):** Cấu hình `basicConstraints = critical, CA:TRUE`, `keyUsage = critical, keyCertSign, cRLSign`. Đóng vai trò là Trust Anchor độc lập, được nạp vào client qua cờ `-CAfile`.



Hình 6.2: Mô hình phân cấp chứng thư X.509 hai tầng triển khai trong phòng lab thực nghiệm.

- **Intermediate CA (`ca.crt`):** Cấu hình `basicConstraints = critical, CA:TRUE, pathlen:0`, `keyUsage = critical, keyCertSign, cRLSign`. Được nạp qua tham số `-untrusted` để chứng minh chuỗi dẫn xuất hợp lệ.
- **Chứng thư máy chủ chuẩn (`server-a.crt`, `server-b.crt`):** Cấu hình `basicConstraints = CA:FALSE`, `keyUsage = digitalSignature, keyEncipherment`, `extendedKeyUsage = serverAuth`, và `subjectAltName = DNS:server-a.test` (hoặc `DNS:server-b.test`).
- **Chứng thư dị biệt phục vụ kiểm thử:**
  - `client-only.crt`: Cấu hình `extendedKeyUsage = clientAuth` (thiếu `serverAuth`) để phục vụ kiểm thử ràng buộc EKU (TC08).
  - `rogue.crt`: Chứng thư tự ký mạo danh, không bắt nguồn từ Root CA trong trust store (TC02).
  - `other-ca/server.crt`: Chứng thư được ký hợp thức nhưng bởi một CA hoàn toàn xa lạ không nằm trong danh mục `-CAfile` của client (TC10).

– `tampered.crt`: Chứng thư bị can thiệp đảo bit ở phần payload chữ ký số (TC05).

6.2.3 Quy trình thực nghiệm

Quy trình được tự động hóa hoàn toàn thông qua tệp điều khiển `Makefile` theo các bước tuần tự:

1. `make clean`: Dọn dẹp toàn bộ dữ liệu tạm và thư mục xuất bản cũ.
2. `make ca`: Tạo cặp khóa RSA 4096-bit, khởi tạo cơ sở dữ liệu CA (`index.txt`, `serial`), và sinh chứng thư tự ký cho Root CA cùng Intermediate CA.
3. `make servers`: Tạo khóa RSA 2048-bit, tạo CSR và ký cấp phát chứng thư cho các máy chủ mục tiêu với các extension tương ứng.
4. `make revoke`: Thu hồi chứng thư `server-a.crt` bằng lệnh `openssl ca -revoke` với mã lý do `keyCompromise`, sau đó kết xuất danh sách thu hồi `ca.crl` bằng lệnh `openssl ca -gencrl`.
5. `make demo-test`: Kích hoạt script `demo/scripts/run_tests.sh` để thực thi 10 ca kiểm thử (TC01–TC10), đối soát exit code và lưu vết kết quả ra tệp `demo/out/results.tsv`.

6.3 Test cases và kết quả

6.3.1 Bảng kết quả thực nghiệm quan sát

Quá trình kiểm thử thực hiện 10 ca kiểm thử độc lập (TC01–TC10) bằng công cụ `openssl verify`. Bảng 6.1 đối chiếu chi tiết giữa điều kiện kiểm thử, kết quả kỳ vọng và kết quả quan sát thực tế thu được từ hệ thống.

Hình 6.3 trích xuất toàn văn kết quả thực thi tự động 10 ca kiểm thử từ giao diện dòng lệnh, xác thực tính khớp tuyệt đối giữa kết quả quan sát thực nghiệm và kỳ vọng thiết kế.



Hình 6.3: Tổng hợp kết quả thực thi tự động bộ 10 ca kiểm thử PKI qua script `run_tests.sh`.

ID	Điều kiện kiểm thử cụ thể	Kỳ vọng	Thực tế	Exit	Mã lỗi / Output quan sát được	Đánh giá
TC01	Chuỗi tin cậy đầy đủ, hostname khớp SAN, EKU `serverAuth` hợp lệ	PASS	PASS	0	`server-a.crt: OK`	Khớp
TC02	Chứng thư tự ký (không có chuỗi dẫn tới Trust Anchor cấu hình)	FAIL	FAIL	2	`error 18: self-signed certificate`	Khớp
TC03	Thời điểm kiểm tra đặt tại mốc tương lai sau ngày hết hạn (`-attime`)	FAIL	FAIL	2	`error 10: certificate has expired`	Khớp
TC04	Hostname truy vấn (`wrong.test`) không trùng khớp với SAN	FAIL	FAIL	2	`error 62: hostname mismatch`	Khớp
TC05	Chữ ký số trên chứng thư bị can thiệp trực tiếp vào payload nhị phân	FAIL	FAIL	2	`error 7: certificate signature failure (invalid padding)`	Khớp
TC06	Bỏ qua chứng thư Intermediate CA trong tham số (`-untrusted`)	FAIL	FAIL	2	`error 20: unable to get local issuer certificate`	Khớp
TC07	Chứng thư đã bị thu hồi và client bật kiểm tra CRL (`-crl_check`)	FAIL	FAIL	2	`error 23: certificate revoked`	Khớp
TC08	Chứng thư chỉ cấp EKU `clientAuth`, client đòi hỏi `sslserver`	FAIL	FAIL	2	`error 26: unsuitable certificate purpose`	Khớp
TC09	Chứng thư còn hạn, chưa bị thu hồi, có nạp CRL hợp lệ	PASS	PASS	0	`server-b.crt: OK`	Khớp
TC10	Chuỗi chứng thư hợp lệ nhưng không dẫn tới Root CA được cấu hình	FAIL	FAIL	2	`error 20: unable to get local issuer certificate`	Khớp

Bảng 6.1: Kết quả quan sát thực nghiệm bộ 10 ca kiểm thử PKI (TC01–TC10).

6.3.2 Phân tích chi tiết các trường hợp quan sát

Dựa trên kết quả quan sát tại Bảng 6.1, các ca kiểm thử được phân nhóm và phân tích chuyên sâu:

- **Nhóm xác minh toàn vẹn mật mã (TC05):** Khi chữ ký số bị sửa đổi bit, quá trình giải mã chữ ký bằng khóa công khai của bên phát hành gặp lỗi đệm PKCS#1 v1.5 (*invalid padding*), OpenSSL lập tức dừng thuật toán và báo `error 7: certificate signature failure`. Đây là bằng chứng cho thấy kiểm tra chữ ký là điều kiện tiên quyết bắt buộc.
- **Nhóm xác minh chuỗi tin cậy (TC02, TC06, TC10):** Nếu thiếu chứng thư trung gian (TC06) hoặc chứng thư thuộc một CA khác không nằm trong Trust Store (TC10), OpenSSL đều trả về `error 20` (`unable to get local issuer certificate`). Trong trường hợp client gặp một chứng thư tự ký không tin cậy (TC02), lỗi trả về là `error 18 (self-signed certificate)`.
- **Nhóm xác minh ngữ cảnh ứng dụng (TC03, TC04, TC08):** Dù chữ ký đúng và chuỗi tin cậy hoàn hảo, OpenSSL vẫn từ chối chứng thư khi sai lệch thời gian (`error 10` ở TC03), sai tên máy chủ (`error 62` ở TC04), hoặc sai mục đích cấp phép (`error 26` ở TC08).
- **Nhóm kiểm tra trạng thái thu hồi (TC07, TC09):** Với chứng thư đã bị đưa vào `ca.crl`, cờ `-crl_check` đã giúp OpenSSL chặn đứng việc sử dụng chứng thư với `error 23 (certificate revoked)`. Ngược lại, chứng thư `server-b.crt` chưa bị thu hồi vẫn vượt qua kiểm tra an toàn (TC09).

6.4 Thảo luận và hạn chế

6.4.1 Đánh giá và trả lời các giả thuyết nghiên cứu

Khẳng định Giả thuyết H_1: Dữ liệu thực nghiệm từ Bảng 6.1 chứng minh H_1 hoàn toàn chính xác. Ngoại trừ TC05 bị hỏng chữ ký, toàn bộ 8 ca kiểm thử còn lại (TC02, TC03, TC04, TC06, TC07, TC08, TC10) đều sở hữu chữ ký số hợp lệ 100% về mặt toán học do CA ký phát hành. Tuy nhiên, cả 8 trường hợp này đều bị OpenSSL trả về mã lỗi (`exit code 2`) và từ chối xác minh. Chỉ có TC01 và TC09 (thỏa mãn đồng thời toàn bộ các điều kiện ngữ cảnh) mới nhận được trạng thái `OK` (`exit code 0`). Điều này chứng minh chữ ký đúng chỉ là điều kiện cần.

Khẳng định Giả thuyết H_2: Dữ liệu thực nghiệm xác nhận tính tương đối của quyết định xác minh: Thay đổi mốc thời gian kiểm tra (`-attime`) làm đảo ngược kết quả từ `OK` sang `error 10`; thay đổi tên máy chủ truy vấn làm phát sinh `error 62`; thay đổi cờ mục đích kiểm tra (`-purpose sslserver`) phát hiện chứng thư sai EKU với `error 26`. Đặc biệt, với ca kiểm thử TC07, chứng thư bị thu hồi chỉ bị từ chối khi client kích hoạt cờ `-crl_check`. Do lệnh `openssl verify` mặc định không kiểm tra thu hồi, nếu không truyền cờ này, chứng thư đã thu hồi vẫn sẽ được client chấp thuận. Quyết định xác minh phụ thuộc hoàn toàn vào cấu hình và chính sách của client tại thời điểm kiểm tra.

Đánh giá Giả thuyết H_3: Quá trình triển khai thực tế cho thấy cơ chế CRL bộc lộ chi phí vận hành rõ rệt: CA phải định kỳ phát hành tệp `ca.crl` mới trước mốc `nextUpdate`, và client phải tải toàn bộ tệp danh sách thu hồi về máy cục bộ. Do phạm vi bài lab tập trung vào tính đúng đắn chức năng (*functional verification*) của quy trình xác minh đường dẫn tĩnh, đề tài chưa thực hiện đo lường hiệu năng (*benchmark*) định lượng về độ trễ mạng hay mức tiêu thụ CPU/băng thông của CRL theo số lượng bản ghi thu hồi. Vì vậy, giả thuyết H_3 được xác nhận ở khía cạnh phân tích kiến trúc lý thuyết và quy trình cấu hình, chưa được kiểm chứng bằng số liệu thực nghiệm đo lường tải.

6.4.2 Hạn chế của bài lab

Mặc dù tái lập thành công các điều kiện biên của RFC 5280, bài lab tồn tại hai hạn chế chính cần ghi nhận:

- **Tính chất cục bộ của môi trường OpenSSL CLI:** Thực nghiệm sử dụng tiện ích dòng lệnh `openssl verify` trên mô hình Root CA nội bộ. Đây là phép thẩm định đường dẫn tĩnh ở tầng thư viện mật mã, không chạy qua tiến trình bắt tay mạng TLS 1.3 hoàn chỉnh (chưa kiểm tra các thông điệp `CertificateVerify` và `Finished`).
- **Khoảng cách với hành vi Web PKI thực tế:** Trình duyệt web thương mại áp dụng các cơ chế linh hoạt hơn nhưng cũng phức tạp hơn so với OpenSSL thuần túy:
  - Trình duyệt hỗ trợ cơ chế AIA Fetching để chủ động tải chứng thư Intermediate CA bị thiếu qua mạng (trong khi OpenSSL báo lỗi ngay ở TC06 nếu thiếu `-untrusted`).
  - Phần lớn trình duyệt hiện đại đã loại bỏ việc kiểm tra CRL trực tiếp từ điểm phân phối (CDP) do vấn đề độ trễ và tính sẵn sàng, thay vào đó sử dụng danh sách thu hồi nén đẩy từ máy chủ cập nhật của hãng trình duyệt (như Google CRLSet, Mozilla OneCRL) hoặc áp dụng cơ chế OCSP Stapling. Do đó, cờ kiểm tra CRL tường minh trong lab không đại diện hoàn toàn cho hành vi mặc định của mọi client trên Internet.

Chương 7

Ứng dụng và hướng phát triển PKI

7.1 Ứng dụng và Certificate Transparency

Cần liên hệ HTTPS/TLS, ký tài liệu, code signing và thiết bị. Giải thích Certificate Transparency giúp phát hiện việc cấp phát sai qua cơ chế nhật ký/giám sát, không tự ngăn chặn CA cấp sai [10].

7.2 Tự động hóa và hậu lượng tử

Cần liên hệ ACME theo RFC 8555 [12]; phân biệt các hướng ký hậu lượng tử với cơ chế thiết lập khóa. Kiểm chứng lại mọi mốc quy định hiện hành từ nguồn chính thức trước khi đưa vào báo cáo cuối.

Kết luận và hướng phát triển

Cần viết sau khi có số liệu: trả lời câu hỏi trung tâm và RQ1–RQ4, đối chiếu H1–H2 với kết quả quan sát; chỉ kết luận về H3 nếu có bằng chứng riêng. Nêu giới hạn của lab và hướng phát triển khả thi. Không tuyên bố đóng góp mới vượt quá phạm vi thử nghiệm.

Tài liệu tham khảo

[1] Whitfield Diffie and Martin E. Hellman. New directions in cryptography. *IEEE Transactions on Information Theory*, 22(6):644–654, 1976.

[2] Ronald L. Rivest, Adi Shamir, and Leonard Adleman. A method for obtaining digital signatures and public-key cryptosystems. *Communications of the ACM*, 21(2):120–126, 1978.

[3] Eric Rescorla. The transport layer security (TLS) protocol version 1.3. Technical Report 8446, RFC Editor, 2018.

[4] Fox-IT. Black tulip: Report of the investigation into the DigiNotar certificate authority breach. Technical Report PR-110202, version 1.0, Fox-IT for the Dutch Ministry of the Interior and Kingdom Relations, 2012. 13 August 2012.

[5] David Cooper, Stefan Santesson, Stephen Farrell, Sharon Boeyen, Russell Housley, and William Polk. Internet X.509 public key infrastructure certificate and certificate revocation list (CRL) profile. Technical Report 5280, RFC Editor, 2008.

[6] Stefan Santesson, Michael Myers, Rich Ankney, Ambarish Malpani, Slava Galperin, and Carlisle Adams. X.509 internet public key infrastructure online certificate status protocol - OCSP. Technical Report 6960, RFC Editor, 2013.

[7] Santosh Chokhani, Warwick Ford, Randy Sabett, Charles Merrill, and Stephen Wu. Internet X.509 public key infrastructure certificate policy and certification practices framework. Technical Report 3647, RFC Editor, 2003.

[8] Magnus Nystrom and Burt Kaliski. PKCS #10: Certification request syntax specification version 1.7. Technical Report 2986, RFC Editor, 2000.

[9] CA/Browser Forum. Baseline requirements for the issuance and management of publicly-trusted certificates, version 2.3.1, 4 october 2026, 2026.

[10] Ben Laurie, Eran Messeri, and Rob Stradling. Certificate transparency version 2.0. Technical Report 9162, RFC Editor, 2021.

[11] Peter Saint-Andre and Rich Salz. Service identity in the transport layer security (TLS) protocol. Technical Report 9525, RFC Editor, 2023.

[12] Richard Barnes, Jacob Hoffman-Andrews, Daniel McCarney, and James Kasten. Automatic certificate management environment (ACME). Technical Report 8555, RFC Editor, 2019.

[13] Phillip Hallam-Baker, Rob Stradling, and Jacob Hoffman-Andrews. DNS certification authority authorization (CAA) resource record. Technical Report 8659, RFC Editor, 2019.